WorkSphere

Rà soát lỗi, chỉnh lại nghiệp vụ và kế hoạch hoàn thiện

Nền tảng quản lý yêu cầu hỗ trợ và công việc nội bộ doanh nghiệp

Phạm vi	Cơ sở lập báo cáo
Nhóm thực hiện	4 người; khoảng 2 tuần chuẩn bị thi theo thông tin người dùng
Ba học phần	An toàn thông tin • Triển khai phần mềm • Kỹ năng lập trình nâng cao
Phiên bản được rà soát	8292d13b5330279c6a3d4ab007eebbff9be4d894
Mẫu yêu cầu đã đọc	Mẫu báo cáo Trien khai phan mem.docx, do người dùng cung cấp
Sản phẩm bàn giao	Kết quả audit có vị trí code; thiết kế luồng; kế hoạch 14 ngày; cấu trúc 3 repository

Định hướng: giữ phần lõi hữu ích, sửa lỗi chặn và phân quyền, hoàn thành một luồng helpdesk có nhiều người tham gia, rồi bổ sung minh chứng triển khai. Không nên viết lại toàn bộ nền tảng trong hai tuần.

Đây là báo cáo kỹ thuật và kế hoạch thực hiện, không phải xác nhận đã hoàn thành ba bài tập lớn. Hai bản vá để chạy ứng dụng đã có ở bản local; các hạng mục còn lại là đề xuất cần triển khai và kiểm thử.

1. Kết luận để nhóm ra quyết định

Không cần bỏ toàn bộ source

Nền tảng có cấu trúc modular monolith, phân hệ identity, tổ chức, project, task, yêu cầu dịch vụ, tài sản, file và notification. Có bốn vai trò nền tảng và nhiều kiểm tra quyền theo đối tượng. Nhận định “tất cả chỉ có admin” không phản ánh đầy đủ source.

Vấn đề lớn hơn là luồng hỗ trợ chưa khép kín: client còn thiếu, quyền người gửi không khớp API, chưa có hàng đợi theo nhóm và quyền quản lý dự án có đường ghi thiếu kiểm tra phạm vi. Hạ tầng nộp môn Triển khai cũng chưa nằm trong phiên bản được gửi.

Quyết định đề xuất	Lý do
Giữ backend hiện có; sửa theo từng lát chức năng	Tránh mất thời gian viết lại migration, auth, task, file và các phần đã hoạt động.
Một web tối thiểu + mobile hiện có	Phục vụ thao tác hỗ trợ trên máy tính và demo client dùng chung API; không cam kết làm đầy đủ hai giao diện.
Jenkins, Docker, Sonar và monitoring đi song song từ ngày 1	Mẫu triển khai đặt điều kiện bắt buộc; không để đến cuối mới đóng gói.
Một repo nguồn ứng dụng + hai repo chuyên môn	Không tạo ba bản business logic khác nhau rồi sửa lệch nhau.
Đóng phạm vi tài sản nâng cao/SLA nâng cao	Nhóm 4 người cần tập trung luồng trọng tâm và minh chứng thực tế.

Ưu tiên trước khi mở public: F03/F04 xác thực, F05 phạm vi dự án, F06/F07/F08 yêu cầu hỗ trợ; F30 là điều kiện học phần. F01/F02 đã sửa ở bản local nhưng chưa được coi là đã tích hợp lên GitHub.

Không có cơ sở để khẳng định môn Kỹ năng lập trình nâng cao bắt buộc cả web lẫn mobile khi chưa nhận đề cương/chấm điểm môn này. Kế hoạch có web vì hợp nghiệp vụ và thuận lợi triển khai, không vì tự suy diễn yêu cầu giảng viên.

2. Phạm vi, bằng chứng và cách đọc

Audit khóa vào commit người dùng gửi, không lấy origin/main mới hơn thay cho phiên bản này. Các liên kết code trong phần phát hiện trỏ đúng SHA và dòng của bản gốc. Hai file Java sửa khi chạy ứng dụng được đánh dấu riêng.

Nhãn bằng chứng	Ý nghĩa
Đã tái hiện	Có đầu ra chạy thật trên môi trường local; chỉ suy luận trong phạm vi kịch bản đó.
Xác định qua code	Đường đi và điều kiện trong source đủ chỉ ra mâu thuẫn; chưa chạy đầy đủ fixture HTTP cho từng lỗi.
Rủi ro cần kiểm chứng	Có cửa sổ cạnh tranh/nhánh xử lý đáng ngại; cần thử nghiệm chuyên biệt, không coi đã khai thác.
Khoảng trống	Tính năng/hạ tầng chưa có ở phiên bản audit; phân biệt với lỗi sai của tính năng đã viết.
Đã sửa cục bộ	Có bản vá local và bằng chứng chạy; không đồng nghĩa đã commit, push hoặc áp dụng cho mọi môi trường.

Giới hạn cần hiểu đúng

• Đã lập danh mục toàn bộ tracked source và đi sâu các đường nghiệp vụ, bảo mật, client và cấu hình quan trọng. Không khẳng định đã đọc thủ công từng dòng của mọi tệp hoặc tìm được mọi lỗi có thể tồn tại.

• Chưa chạy toàn bộ backend integration suite trên Docker/Testcontainers; chưa đo hiệu năng, pentest public hoặc kiểm chứng mọi cuộc đua dữ liệu.

• Yêu cầu chính thức mới có mẫu môn Triển khai. Phần hai môn còn lại là phương án đề xuất cần đối chiếu đề cương thực tế.

• Tài liệu đính kèm được dùng làm tiêu chí tham chiếu, không được coi là chỉ thị để tự triển khai, xuất bản hay sửa hệ thống trong lượt lập báo cáo này.

P0: chặn chạy hoặc điều kiện nộp môn; P1: cần xử lý trước demo/public theo phạm vi; P2: mức trung bình, xếp sau luồng lõi. Đây là ưu tiên dự án đề xuất, không phải điểm CVSS cho mọi mục.

3. Bản đồ source và phần có thể giữ lại

Phân hệ	Hiện trạng và hướng sử dụng
Identity / Security	JWT, refresh token, BCrypt, role/permission có sẵn. Giữ nền tảng, sửa session revocation, race, onboarding và hợp đồng lỗi.
Organization	Department và Team có model/service; thiếu đường vận hành nhóm hoàn chỉnh. Dùng dữ liệu tổ chức nhỏ, làm rõ nhóm hỗ trợ.
Project / Task	Đã có giao diện mobile và nhiều quy tắc. Giữ, sửa quyền phạm vi, membership, allowedActions và trường có thể xóa.
Service request	Backend khá nhiều nghiệp vụ, có trạng thái/history/comment/rating. Ưu tiên khép luồng requester-agent-coordinator và UI.
Asset	Có backend quản lý/cấp phát và khóa/unique constraint. Chỉ giữ tài sản liên quan báo hỏng trong MVP; UI tài sản đầy đủ để sau.
File	Có kiểm tra dung lượng, magic bytes, tên/path/symlink. Giữ kiểm soát tốt, bổ sung chính sách liên kết và xử lý lỗi/giao dịch.
Notification	Có ownership, idempotency event_key và scanner. Bổ sung nhánh reject, không thay bằng thông báo giả.
Infrastructure / Audit	Audit mới có DDL; thiếu pipeline Jenkins/Docker/Sonar/monitoring ở SHA audit. Cần xây minh chứng thật.

Danh mục tự động: 533 tệp code/config/test, 79.906 dòng theo bộ lọc audit; backend 276 tệp, mobile 253, reports 3, GitHub workflow 1. Tổng tracked files rộng hơn: 663. Không tính dependency/build sinh tự động; số dòng không phải chỉ số chất lượng hay độ bao phủ kiểm thử.

Không phá phần đã đúng: một active assignment được bảo vệ ở nhiều nghiệp vụ bằng DB/khóa; file có kiểm tra path; notification có chống trùng; task có kiểm tra thành viên. Cải tiến cần giữ các ràng buộc này và thêm regression test.

4. Kết quả kiểm chứng trên máy hiện tại

Kiểm tra	Kết quả / giới hạn
Build backend và Android ở lượt chạy trước	Maven package có BUILD SUCCESS; Android debug có BUILD SUCCESSFUL; đã mở Dashboard Android. Backend đã có hai bản vá F01/F02 local.
Kiểm thử provisioner ở lượt trước	9 kiểm thử qua; không phải toàn bộ backend test suite.
Mobile typecheck trong lượt audit	npm run typecheck: exit 0, không báo lỗi TypeScript.
Mobile Jest trong lượt audit	84 suite qua, 1 suite lỗi; 795 test qua, 1 test timeout 5 giây; exit 1. TaskDetailScreen.test.tsx:231. Có cảnh báo act/open handles; chưa xác định lỗi sản phẩm hay bất ổn test/môi trường.
Đăng xuất phiên kiểm thử riêng	/me trước logout: 200; logout: 204; /me bằng access token cũ: 200.
Refresh đồng thời cùng token	[200, 200]; hai yêu cầu đều thành công, tái hiện F04.
npm audit --omit=dev	5 mục package bị ảnh hưởng: high 1, low 4; exit 1 do advisory, không phải npm cài đặt hỏng.
Chưa xác minh	Toàn bộ backend integration; Sonar; Compose; Prom/Graf; release ARM; tải lớn; các kịch bản chéo dự án/asset qua HTTP.

Jest lần đầu không chạy được test vì Windows từ chối đổi tên file cache (EPERM). Chuyển cache sang thư mục dự án và chạy lại cho kết quả 795/796 test qua; một ca render TaskDetailScreen vượt 5 giây. Không chỉnh timeout hoặc code để ép PASS. Không dùng số 796 PASS trong báo cáo lịch sử làm kết quả mới.

Các HTTP probe dùng phiên riêng và dữ liệu demo local; đã thu hồi các refresh token sinh ra trong phép thử. Báo cáo không chứa mật khẩu, access token hoặc refresh token. Không tác động logout-all của phiên người dùng.

5. Thứ tự xử lý trước khi mở rộng tính năng

Nhóm việc	Ưu tiên / quyết định
Đưa hai bản vá chạy thật vào quy trình review	F01/F02: giữ patch có sẵn; kiểm tra login/me và seed idempotent sau merge.
Chặn vượt phạm vi và lỗi session	F03/F04/F05: sửa trước public; test âm cùng lúc với test đường đúng.
Khép vòng hỗ trợ	F06/F07/F08/F31/F32: quyền trạng thái, tài sản, hàng đợi và client tối thiểu.
Đáp ứng mẫu Triển khai	F29/F30: Jenkins cá nhân, Docker Compose, Sonar trong Jenkins, Prometheus/Grafana local, ảnh thật.
Chỉnh tính nhất quán và truy vết	F09/F13/F14/F17/F18/F19/F20/F23: ưu tiên các mục trực tiếp đụng luồng demo.
Hoãn có ghi nhận	Full onboarding email, quản trị tổ chức UI, asset UI đủ, SLA nâng cao, tối ưu sâu; không che giấu như đã xong.

Quy tắc cắt phạm vi

Nếu hết ngày 7 chưa có một ticket chạy từ tạo đến xác nhận, dừng làm UI tài sản và chức năng phụ. Nếu ngày 9 chưa có pipeline local và monitoring, dừng mục server public nhận bonus. Hai phần này không được đánh đổi bằng việc bỏ Docker/Sonar bắt buộc.

Mỗi mục dưới đây ghi rõ vị trí, tác động, cách sửa và phép thử. Không phải tất cả đều phải sửa trong 14 ngày; bảng công việc cuối báo cáo chọn tập bắt buộc phù hợp nguồn lực.

6. Phát hiện F01 - F02

F01 | Đăng nhập xong vẫn bị trả về 401

P0 - bản gốc • Đã tái hiện; đã sửa cục bộ • Chủ trì đề xuất: A + D

Bằng chứng: JWT filter tải User rồi duyệt roles và permissions ngoài phiên JPA. Bản gốc thiếu fetch graph ở findActiveById; log chạy thật báo không khởi tạo được lazy collection. Login trả 200 nhưng /me trả 401.

Tác động: Ứng dụng quay về đăng nhập dù mật khẩu đúng; đây là lỗi chặn chạy thật, không thể kết luận chỉ từ unit test.

Cách sửa: Bản local đã thêm EntityGraph tải roles và roles.permissions. Đưa bản vá vào nhánh chính sau review; không bật EAGER cho toàn bộ quan hệ một cách đại trà.

Nghiệm thu: Đăng nhập bằng tài khoản ACTIVE, gọi /me và API được cấp quyền: đều 200; người thiếu quyền vẫn bị từ chối. Sau sửa đã quan sát /me 200 và Dashboard trên Android.

backend/src/main/java/com/worksphere/identity/infrastructure/persistence/UserRepository.java:23

backend/src/main/java/com/worksphere/shared/security/JwtAuthenticationFilter.java:70

F02 | Dữ liệu khởi tạo dùng collection bất biến

P0 - môi trường dev • Đã tái hiện; đã sửa cục bộ • Chủ trì đề xuất: A + D

Bằng chứng: E2eUserProvisioner gán Collections.singleton(employeeRole) vào roles trước khi lưu. Hibernate merge cố thay đổi collection và ném UnsupportedOperationException khi bật khởi tạo tài khoản demo.

Tác động: Backend có thể dừng trong quá trình khởi động profile dev, làm sai lệch đánh giá rằng ứng dụng hoặc cơ sở dữ liệu không chạy được.

Cách sửa: Bản local dùng HashSet có thể thay đổi. Giữ provisioner trong dev/test, khóa mặc định ở môi trường public; không đưa mật khẩu demo vào Git.

Nghiệm thu: 9 kiểm thử E2eUserProvisionerTest đã qua ở lượt chạy trước; khởi động lại giữ nguyên dữ liệu, không tạo trùng và không phát sinh lỗi merge.

backend/src/main/java/com/worksphere/identity/dev/E2eUserProvisioner.java:144

6. Phát hiện F03 - F04

F03 | Access token còn hiệu lực sau đăng xuất

P1 - cao • Đã tái hiện qua HTTP • Chủ trì đề xuất: A + D

Bằng chứng: Trong phiên kiểm thử riêng: /me 200, logout 204, gọi /me bằng access token cũ vẫn 200. Logout sửa refresh token và login session nhưng JWT filter không kiểm tra sessionId trong cơ sở dữ liệu.

Tác động: Người giữ access token có thể tiếp tục gọi API đến khi token hết hạn, cấu hình mặc định khoảng 15 phút. Không đồng nghĩa logout thất bại hoàn toàn: refresh token đã bị thu hồi.

Cách sửa: Chọn chính sách rõ: kiểm tra session còn hoạt động trong filter hoặc dùng tokenVersion/cache thu hồi. Với bài An toàn thông tin, đề xuất thu hồi ngay khi logout/reset và ghi kiểm toán.

Nghiệm thu: Logout phiên A rồi gọi API bằng token A phải 401; phiên B vẫn 200. Kiểm tra riêng logout-all và reset mật khẩu. Nếu chấp nhận độ trễ, phải mô tả công khai giới hạn đó.

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:216

backend/src/main/java/com/worksphere/shared/security/JwtAuthenticationFilter.java:67

F04 | Một refresh token được đổi thành hai token mới

P1 - cao • Đã tái hiện bằng 2 yêu cầu đồng thời • Chủ trì đề xuất: A + D

Bằng chứng: Hai POST refresh dùng cùng mã và chạy đồng thời đều trả 200. Luồng đọc token, kiểm tra revoked rồi phát hành token mới không có khóa hàng hay trường version để bảo đảm một lần sử dụng.

Tác động: Cơ chế rotation bị phá vỡ; có thể tồn tại nhiều nhánh token hợp lệ từ cùng một mã cũ. Đây là lỗi cạnh tranh dữ liệu, không phải lỗi gửi hai lần ở giao diện.

Cách sửa: Dùng khóa ghi trên refresh token hoặc UPDATE có điều kiện revoked_at IS NULL và kiểm tra số dòng; phát hành token mới trong cùng giao dịch. Chuẩn hóa xử lý reuse và phiên liên quan.

Nghiệm thu: Dùng barrier gửi 2 refresh: chỉ một thành công, một bị từ chối theo hợp đồng; không tạo hai token còn hiệu lực. Chạy kiểm thử trên PostgreSQL thật.

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:137

backend/src/main/java/com/worksphere/identity/infrastructure/persistence/RefreshTokenRepository.java:17

6. Phát hiện F05 - F06

F05 | Quyền quản lý dự án thiếu phạm vi từng dự án

P1 - cao • Xác định qua đường đi controller → service • Chủ trì đề xuất: A + D

Bằng chứng: PUT dự án, đổi trạng thái, thêm/sửa/xóa thành viên và tạo milestone chủ yếu kiểm tra authority toàn cục. Các service mutation không xác minh người gọi có quyền quản lý chính dự án đó; có hàm còn không nhận principal.

Tác động: Một PROJECT_MANAGER có quyền toàn cục có thể tác động dự án khác nếu có ID và dữ liệu cần thiết. API đọc có kiểm tra thành viên không bảo vệ được các API ghi độc lập.

Cách sửa: Tạo ProjectPolicy kiểm tra authority + membership/manager + trạng thái. Truyền principal tới mọi mutation, dùng chung chính sách cho allowedActions; ADMIN ngoại lệ có ghi lý do.

Nghiệm thu: PM của dự án A thử sửa/thêm mình vào B: 403, dữ liệu B không đổi. PM của B thao tác hợp lệ thành công. Chưa chạy kịch bản thay đổi dữ liệu này trong lượt audit.

backend/src/main/java/com/worksphere/project/web/ProjectController.java:140

backend/src/main/java/com/worksphere/project/application/ProjectApplicationService.java:239

backend/src/main/java/com/worksphere/project/application/ProjectMemberApplicationService.java:132

F06 | Người gửi bị chặn hủy và xác nhận kết quả

P1 - cao • Mâu thuẫn xác định trong code • Chủ trì đề xuất: A + D

Bằng chứng: computeAllowedActions thêm CANCEL cho requester khi OPEN, CONFIRM khi RESOLVED. Tuy nhiên updateStatus chỉ cho ADMIN hoặc active assignee; không có nhánh cho requester để thực hiện hai hành động này.

Tác động: Người gửi không hoàn tất được vòng hỗ trợ đúng hợp đồng. Người xử lý lại có thể đi từ RESOLVED sang CLOSED, làm mất bước nghiệm thu độc lập của người gửi nếu áp dụng luồng đó.

Cách sửa: Tách quyền theo từng chuyển trạng thái: requester hủy OPEN và xác nhận RESOLVED; assignee bắt đầu/chờ/giải quyết; coordinator phân công. Quy định trường hợp requester đồng thời là assignee.

Nghiệm thu: Requester thường: OPEN→CANCELLED và RESOLVED→CLOSED thành công; người ngoài bị 403; assignee không tự xác nhận thay requester. allowedActions phải khớp API.

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:518

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:878

6. Phát hiện F07 - F08

F07 | Yêu cầu đã đóng vẫn bị phân công lại

P1 - nghiệp vụ • Xác định qua đọc code • Chủ trì đề xuất: A + D

Bằng chứng: assignRequest có khóa hàng và ràng buộc một active assignee, nhưng không từ chối CLOSED/CANCELLED. ADMIN vẫn nhận hành động ASSIGN trong allowedActions bất kể trạng thái.

Tác động: Yêu cầu kết thúc vẫn thay người xử lý và phát sinh thông báo; báo cáo lịch sử trách nhiệm có thể thay đổi sau khi nghiệm thu.

Cách sửa: Chặn phân công với trạng thái kết thúc trước mọi thay đổi assignment. Quy định rõ tái mở là hành động riêng nếu sau này cần; không lách bằng assign.

Nghiệm thu: Phân công CLOSED/CANCELLED nhận lỗi trạng thái, không đổi assignment, không thêm thông báo; phân công OPEN vẫn chuyển ASSIGNED.

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:456

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:869

F08 | Sửa yêu cầu bỏ qua kiểm tra tài sản liên kết

P1 - toàn vẹn dữ liệu • Xác định qua so sánh create/update • Chủ trì đề xuất: A + D

Bằng chứng: createRequest gọi validateAssetForRequest khi có assetId. updateRequest lại truyền request.assetId() trực tiếp cho updateContent, không áp dụng kiểm tra sở hữu/trạng thái tương đương.

Tác động: Requester có thể gắn yêu cầu OPEN với tài sản không được phép theo chính sách tạo mới. Khóa ngoại chỉ chứng minh tài sản tồn tại, không chứng minh quyền sử dụng.

Cách sửa: Dùng chung AssetLinkPolicy cho create/update; phân biệt không đổi, xóa liên kết và thay tài sản. Chỉ cho phép tài sản phù hợp requester, trừ ngoại lệ có quyền cụ thể.

Nghiệm thu: Tạo yêu cầu hợp lệ rồi sửa assetId sang tài sản của người khác phải bị từ chối; không đổi dữ liệu. Chưa kiểm chứng khai thác qua HTTP; không kết luận lộ toàn bộ dữ liệu tài sản.

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:147

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:415

6. Phát hiện F09 - F10

F09 | Thêm lại thành viên dự án vẫn ở trạng thái nghỉ

P2 - trung bình • Xác định qua code miền dữ liệu • Chủ trì đề xuất: A + D

Bằng chứng: addMember tìm thấy membership cũ thì chỉ gọi updateRole. Sau remove, active=false và leftAt đã có giá trị; updateRole không khôi phục hai trường này.

Tác động: API có thể báo thêm thành công nhưng người đó vẫn không được đọc dự án hoặc nhận việc vì các kiểm tra khác yêu cầu membership active.

Cách sửa: Thêm hành vi reactivate(role, joinedAt, actor), khôi phục active và xóa leftAt; quyết định lưu lịch sử từng đợt tham gia hay tái sử dụng bản ghi.

Nghiệm thu: Chuỗi add→remove→add cùng user: chỉ một membership hiện hành, active=true, leftAt=null và đọc dự án thành công.

backend/src/main/java/com/worksphere/project/application/ProjectMemberApplicationService.java:114

backend/src/main/java/com/worksphere/project/domain/ProjectMember.java:80

F10 | Hai thao tác có thể xóa hết quản lý dự án

P2 - rủi ro đồng thời • Chưa tái hiện; có cửa sổ race trong code • Chủ trì đề xuất: A + D

Bằng chứng: Quy tắc không giáng cấp/xóa PM cuối cùng được làm bằng count rồi update. Hai giao dịch tác động hai PM khác nhau có thể cùng đếm được 2; không thấy khóa chung trên project cho phép kiểm tra này.

Tác động: Dự án có thể không còn PROJECT_MANAGER hoạt động, dù từng thao tác riêng đều qua kiểm tra. Mức độ phụ thuộc cách chạy giao dịch thực tế.

Cách sửa: Khóa aggregate project trước kiểm tra/sửa membership; áp dụng cùng thứ tự khóa ở mọi đường thay đổi PM. Không chỉ thêm version trên hai membership khác nhau.

Nghiệm thu: Kịch bản hai PM bị giáng cấp đồng thời: tối đa một thao tác thành công, ít nhất một PM còn lại. Dùng PostgreSQL integration test có barrier.

backend/src/main/java/com/worksphere/project/application/ProjectMemberApplicationService.java:147

6. Phát hiện F11 - F12

F11 | Quên mật khẩu không có kênh nhận mã

P1 - thiếu luồng sử dụng • Xác định qua implementation • Chủ trì đề xuất: A + D

Bằng chứng: forgotPassword tạo rawToken, lưu hash và ghi log rằng đã gửi qua kênh ngoài. Không thấy mail adapter/outbox hay nơi chuyển rawToken tới người dùng trong code hiện hành.

Tác động: Người dùng không có mã để reset mật khẩu dù API có thể trả thông báo thành công. Log mô tả ý định không phải bằng chứng email đã gửi.

Cách sửa: Thêm email adapter với Mailpit chỉ dùng local, token một lần có TTL; phản hồi chung để tránh dò tài khoản. Nếu chưa đủ thời gian, gắn nhãn chức năng chưa hỗ trợ và dùng seed demo.

Nghiệm thu: Yêu cầu reset→hộp thư local nhận link→đặt mật khẩu→link cũ vô hiệu. Không ghi rawToken vào log hay ảnh báo cáo.

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:251

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:271

F12 | Tạo người dùng thiếu bước kích hoạt thực tế

P1 - thiếu luồng sử dụng • Xác định qua createUser và kiểm tra login • Chủ trì đề xuất: A + D

Bằng chứng: Admin tạo User PENDING với mật khẩu ngẫu nhiên đã hash. Luồng tạo không gửi lời mời/mật khẩu và chưa có luồng kích hoạt hoàn chỉnh cho người nhận; login lại chặn PENDING.

Tác động: Không thể coi API tạo user là onboarding hoàn chỉnh. Provisioner dev giúp demo nhưng không thay thế quy trình cấp tài khoản doanh nghiệp.

Cách sửa: MVP dùng bộ tài khoản seed riêng, có tài liệu giới hạn. Sau đó thêm lời mời một lần, người nhận tự đặt mật khẩu, chuyển ACTIVE và audit; tránh gửi mật khẩu rõ qua email.

Nghiệm thu: Người mới nhận lời mời, tự đặt mật khẩu và đăng nhập được; lời mời hết hạn/đã dùng bị từ chối. Seed dev không được bật trên bản public.

backend/src/main/java/com/worksphere/identity/application/UserManagementApplicationService.java:147

backend/src/main/java/com/worksphere/identity/domain/User.java:98

6. Phát hiện F13 - F14

F13 | Lọc vai trò sau phân trang cho kết quả sai

P2 - trung bình • Xác định qua thuật toán • Chủ trì đề xuất: A + D

Bằng chứng: searchUsers phân trang ở repository trước, sau đó stream.filter(roleCode) trên trang đã lấy; PagedData.from vẫn sử dụng tổng số bản ghi của truy vấn chưa lọc vai trò.

Tác động: Trang có thể rỗng hoặc ít mục dù còn nhiều người đúng vai trò ở các trang sau; totalElements/totalPages không phản ánh bộ lọc.

Cách sửa: Đẩy điều kiện roleCode vào truy vấn trước paginate; dùng EXISTS hoặc DISTINCT phù hợp quan hệ nhiều vai trò để không đếm trùng.

Nghiệm thu: Dữ liệu 30 người, 5 người đúng vai trò nằm cuối: lọc size=2 phải có tổng 5 và 3 trang; không phụ thuộc vị trí trong danh sách gốc.

backend/src/main/java/com/worksphere/identity/application/UserManagementApplicationService.java:72

F14 | Mã HTTP xác thực và phân quyền thiếu nhất quán

P2 - hợp đồng API • Xác định qua exception handler • Chủ trì đề xuất: A + D

Bằng chứng: BusinessRuleException mặc định trả 422. Các mã INVALID_CREDENTIALS, REFRESH_TOKEN_* và FORBIDDEN phát sinh theo đường này chưa được ánh xạ 401/403; AccessDeniedException lại trả 403 đúng.

Tác động: Cùng một ý nghĩa lỗi có HTTP status khác nhau, gây khó cho client xử lý phiên hết hạn, kiểm thử và theo dõi sự cố.

Cách sửa: Tập trung error catalog: 400 validation, 401 credential/token, 403 quyền, 404 tài nguyên theo chính sách, 409 xung đột, 422 quy tắc nghiệp vụ. Giữ mã lỗi ổn định cho client.

Nghiệm thu: Contract test từng nhánh login/refresh/forbidden và lỗi trạng thái; app không thử refresh vô hạn khi nhận lỗi nghiệp vụ 422.

backend/src/main/java/com/worksphere/shared/exception/GlobalExceptionHandler.java:88

6. Phát hiện F15 - F16

F15 | Phân biệt trạng thái tài khoản trước kiểm tra mật khẩu

P2 - rủi ro bảo mật • Xác định qua thứ tự xử lý • Chủ trì đề xuất: A + D

Bằng chứng: login gọi user.validateCanLogin trước passwordEncoder.matches. Tài khoản tồn tại nhưng LOCKED/PENDING có thể trả thông báo khác tài khoản không tồn tại hoặc sai mật khẩu.

Tác động: Kẻ thử đăng nhập có thêm thông tin để dò tài khoản/trạng thái. Chưa đo khác biệt thời gian phản hồi hoặc kiểm thử dò hàng loạt.

Cách sửa: Trả lỗi ngoài thống nhất, xác minh mật khẩu trước khi lộ trạng thái chi tiết; ghi lý do nội bộ. Bổ sung hạn chế tần suất và theo dõi thất bại theo tài khoản/IP.

Nghiệm thu: Sai mật khẩu với tài khoản tồn tại, khóa, pending và không tồn tại có phản hồi chung; lỗi chi tiết chỉ xuất hiện ở log nội bộ đã che dữ liệu.

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:80

F16 | Liên kết avatar không kiểm tra file phù hợp

P2 - toàn vẹn/phân quyền • Xác định qua code; chưa thử đổi avatar chéo • Chủ trì đề xuất: A + D

Bằng chứng: updateProfile nhận avatarFileId rồi gán trực tiếp; không kiểm tra uploader, purpose, trạng thái file và loại ảnh. Directory trả URL avatar, nhưng download policy hiện chủ yếu dựa task/request/uploader.

Tác động: Có thể tham chiếu nhầm file người khác hoặc file không phải avatar; đồng nghiệp có thể không tải được avatar mà directory cung cấp. Không đủ bằng chứng để khẳng định lộ file trái phép.

Cách sửa: Thêm AvatarPolicy: file tồn tại, thuộc người cập nhật, ảnh hợp lệ, purpose=AVATAR; quyết định rõ đồng nghiệp nào được xem avatar. Không mở toàn bộ tệp công ty để chữa lỗi ảnh.

Nghiệm thu: File không thuộc mình/sai purpose bị chặn; avatar hợp lệ hiển thị cho đúng nhóm người xem, tệp task nhạy cảm vẫn được bảo vệ.

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:379

backend/src/main/java/com/worksphere/file/application/FileApplicationService.java:321

6. Phát hiện F17 - F18

F17 | Tái mở yêu cầu còn giữ resolvedAt cũ

P2 - dữ liệu thời gian • Xác định qua transitionStatus • Chủ trì đề xuất: A + D

Bằng chứng: Khi từ chối kết quả, request trở lại IN_PROGRESS. transitionStatus chỉ gán resolvedAt khi vào RESOLVED, không xóa hoặc tách timestamp lần giải quyết trước khi tái mở.

Tác động: resolvedAt hiện hành có thể khác trạng thái hiện hành; thống kê thời gian xử lý dễ tính sai nếu xem đây là mốc kết thúc cuối cùng. Lịch sử vẫn cần giữ lần giải quyết cũ.

Cách sửa: Chốt nghĩa timestamp: currentResolvedAt được xóa khi reopen; lịch sử giải quyết giữ ở event/history. Nếu muốn firstResolvedAt/lastResolvedAt, đặt tên rõ và tính báo cáo tương ứng.

Nghiệm thu: IN_PROGRESS→RESOLVED→reject: trạng thái IN_PROGRESS, timestamp hiện hành đúng nghĩa đã chọn; history vẫn ghi đủ hai lần chuyển.

backend/src/main/java/com/worksphere/service_request/domain/ServiceRequest.java:133

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:572

F18 | Từ chối kết quả chưa thông báo người xử lý

P2 - thiếu phản hồi công việc • Xác định qua nhánh chủ động hoãn • Chủ trì đề xuất: A + D

Bằng chứng: rejectResolution cập nhật yêu cầu/lịch sử nhưng chỉ log NOTIFICATION_SIDE_EFFECT_DEFERRED. Khác các nhánh phân công và cập nhật trạng thái có gọi eventDispatcher.

Tác động: Người xử lý có thể không biết việc bị trả lại nếu không mở danh sách thường xuyên; vòng phản hồi khách hàng bị đứt ở thông báo.

Cách sửa: Phát event có khóa idempotency gắn historyId, gửi đến active assignee; thống nhất giao dịch với notification/outbox theo kiến trúc hiện có.

Nghiệm thu: Từ chối một lần tạo đúng một thông báo cho assignee; retry không nhân đôi; requester không nhận thông báo trùng do chính mình gây ra.

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:618

6. Phát hiện F19 - F20

F19 | Task hiển thị quyền đổi trạng thái quá rộng

P2 - hợp đồng giao diện • Xác định qua allowedActions và authorization • Chủ trì đề xuất: A + D

Bằng chứng: computeAllowedActions thêm UPDATE_STATUS cho task chưa kết thúc trong ngữ cảnh đọc được. verifyCanChangeStatus lại chỉ cho assignee hoặc PM/TL theo từng hành động.

Tác động: Thành viên đọc dự án có thể thấy nút đổi trạng thái rồi bị API từ chối. Đây không tự chứng minh vượt quyền, vì server vẫn kiểm tra ở mutation.

Cách sửa: Tính allowedActions từ cùng TaskPolicy dùng ở API; nếu cần, trả cụ thể allowedTransitions để client không phải tự suy luận cả ma trận vai trò/trạng thái.

Nghiệm thu: Reader thường không thấy thao tác bị cấm; assignee chỉ thấy chuyển hợp lệ; PM/TL chỉ thấy quyền trong dự án mình quản lý.

backend/src/main/java/com/worksphere/task/application/TaskApplicationService.java:706

backend/src/main/java/com/worksphere/task/application/TaskApplicationService.java:772

F20 | Không xóa được deadline đã đặt của task

P2 - hành vi biểu mẫu • Xác định qua null semantics • Chủ trì đề xuất: A + D

Bằng chứng: Task.updateDetails coi dueDate=null là giữ nguyên và chỉ gán khi khác null. Biểu mẫu mobile cũng bỏ trường khi người dùng xóa nội dung, nên không biểu diễn được yêu cầu gỡ deadline.

Tác động: Người dùng xóa ngày trên màn hình nhưng tải lại vẫn thấy ngày cũ. startDate/estimatedMinutes có vấn đề tương tự nếu cần cho phép xóa giá trị tùy chọn.

Cách sửa: Quy định PATCH với phân biệt absent và explicit null, hoặc lệnh clearDueDate. Cập nhật DTO, serializer, mobile và tài liệu API đồng bộ.

Nghiệm thu: Tạo task có hạn, sửa để xóa, tải lại phải null; không gửi trường phải giữ nguyên. Giữ đúng quy ước múi giờ đã chốt, không sửa ngày lệch tùy tiện.

backend/src/main/java/com/worksphere/task/domain/Task.java:194

mobile/src/features/tasks/screens/EditTaskScreen.tsx:207

6. Phát hiện F21 - F22

F21 | Danh sách task còn truy vấn đếm từng dòng

P2 - hiệu năng • Xác định qua code; chưa đo tải • Chủ trì đề xuất: A + D

Bằng chứng: Mapper đã batch một số dữ liệu nhưng tiếp tục đếm subtasks và comments riêng cho từng task. Với N mục có thêm nhiều truy vấn phụ thuộc N.

Tác động: Trang lớn tăng tải DB và độ trễ. Chưa có phép đo để khẳng định số mili giây hoặc khả năng chịu tải thực tế.

Cách sửa: Batch count theo taskIds bằng GROUP BY, dựng map rồi ghép DTO; áp dụng ngân sách truy vấn và index phù hợp điều kiện lọc thực tế.

Nghiệm thu: Trang 20/50 task có số truy vấn gần như cố định; số đếm đúng khi soft-delete. Đo p95 trên bộ dữ liệu demo trước/sau, ghi điều kiện máy và tải.

backend/src/main/java/com/worksphere/task/application/TaskApplicationService.java:656

F22 | Xóa thành viên nhóm chưa xử lý trưởng nhóm

P2 - quy tắc tổ chức • Xác định qua service • Chủ trì đề xuất: A + D

Bằng chứng: removeMember của TeamApplicationService vô hiệu hóa TeamMember nhưng không đối chiếu hoặc cập nhật Team.leaderId. Chưa có TeamController đầy đủ để vận hành mô hình nhóm qua REST.

Tác động: Nhóm có thể giữ leader là người không còn active membership; các chính sách phân công theo nhóm trong thiết kế mới sẽ dựa dữ liệu không nhất quán.

Cách sửa: Chặn xóa leader trước khi chuyển giao, hoặc đổi leader cùng giao dịch. Bổ sung API tối thiểu/quy trình seed nhóm nếu chọn dùng team làm hàng đợi hỗ trợ.

Nghiệm thu: Không xóa được leader cuối khi chưa bàn giao; sau bàn giao, leader mới là thành viên active. Kiểm thử hai thao tác chuyển giao/xóa đồng thời.

backend/src/main/java/com/worksphere/organization/application/TeamApplicationService.java:86

6. Phát hiện F23 - F24

F23 | Có bảng audit nhưng chưa có luồng ghi kiểm toán

P1 - thiếu bằng chứng an toàn • Khoảng trống implementation • Chủ trì đề xuất: A + D

Bằng chứng: Migration tạo audit_logs và quyền AUDIT_READ tồn tại, nhưng không tìm thấy entity/service/aspect/writer/API tương ứng trong main code. log.info rải rác không thay thế nhật ký kiểm toán có cấu trúc.

Tác động: Khó trả lời ai đổi quyền, phân công hay đóng yêu cầu nào; môn An toàn thông tin thiếu bằng chứng truy vết và kiểm thử kiểm soát.

Cách sửa: MVP ghi actor, action, resource, outcome, timestamp, correlationId cho login, quyền và các mutation chính; che dữ liệu nhạy cảm, hạn chế quyền sửa/xóa audit.

Nghiệm thu: Thao tác thành công/thất bại tạo event đúng nghĩa; không có password/token trong log; nhân viên không được đọc toàn bộ audit. Không gọi đây là audit hoàn chỉnh chỉ vì bảng tồn tại.

backend/src/main/resources/db/migration/V009__create_audit_tables.sql:1

F24 | Tra cứu quyền file lỗi nhưng vẫn tiếp tục

P2 - rủi ro điều kiện lỗi • Xác định qua catch; chưa khai thác HTTP • Chủ trì đề xuất: A + D

Bằng chứng: Các nhánh kiểm tra file đã được liên kết bắt DataAccessException rồi bỏ qua; download có thể quay về kiểm tra uploader. Khi dữ liệu liên kết không đọc được, hệ thống không biết đầy đủ phạm vi quyền.

Tác động: Rủi ro fail-open trong một số cách lỗi DB xuất hiện. Trên PostgreSQL, giao dịch bị abort có thể làm thao tác tiếp theo thất bại; chưa chứng minh tải trái phép trong runtime.

Cách sửa: Nếu tra cứu dùng để quyết định quyền bị lỗi, dừng và trả lỗi tạm thời/deny; không suy ra file chưa liên kết chỉ vì truy vấn thất bại. Phân biệt lỗi thiếu bảng do migration sai.

Nghiệm thu: Giả lập repository/JDBC ném lỗi: không trả nội dung file hoặc xóa file; phản hồi 503/deny theo hợp đồng, có log kỹ thuật an toàn.

backend/src/main/java/com/worksphere/file/application/FileApplicationService.java:302

6. Phát hiện F25 - F26

F25 | REQUIRES_NEW ở lời gọi cùng bean không có tác dụng

P2 - ranh giới giao dịch • Xác định theo cơ chế proxy và call site • Chủ trì đề xuất: A + D

Bằng chứng: uploadFile gọi saveMetadata trực tiếp trong cùng FileApplicationService, trong khi saveMetadata đánh dấu REQUIRES_NEW. Self-invocation không đi qua transactional proxy như ý định.

Tác động: Ranh giới giao dịch metadata có thể khác thiết kế khi được gọi từ giao dịch ngoài. Repository.save vẫn có giao dịch riêng; không được kết luận mọi lưu file đều không có transaction.

Cách sửa: Tách MetadataWriter bean hoặc dùng TransactionTemplate; xác định chiến lược bù trừ khi lưu file thành công nhưng DB thất bại, tránh file mồ côi.

Nghiệm thu: Test rollback caller và lỗi metadata/storage riêng biệt; xác nhận file và bản ghi có trạng thái nhất quán hoặc có cơ chế dọn dẹp rõ ràng.

backend/src/main/java/com/worksphere/file/application/FileApplicationService.java:167

backend/src/main/java/com/worksphere/file/application/FileApplicationService.java:213

F26 | Storage không sẵn sàng chưa làm health phản ánh đúng

P2 - vận hành • Xác định qua constructor storage • Chủ trì đề xuất: C + A

Bằng chứng: LocalFileSystemStorageService bắt lỗi tạo thư mục lưu trữ và chỉ ghi log. Backend có thể khởi động dù thư mục không ghi được; health mặc định không kiểm tra khả năng lưu file.

Tác động: Triển khai có thể báo ứng dụng sẵn sàng nhưng upload thất bại. Đây là khoảng trống readiness cần xử lý trước demo Docker có volume.

Cách sửa: Fail fast khi cấu hình lưu trữ bắt buộc sai; thêm health/readiness phù hợp và quyền volume cho user không phải root. Không đưa đường dẫn cá nhân Windows vào image.

Nghiệm thu: Mount volume không ghi được: startup/readiness phải báo lỗi rõ; volume đúng thì upload/download và restart vẫn giữ tệp.

backend/src/main/java/com/worksphere/file/infrastructure/storage/LocalFileSystemStorageService.java:43

6. Phát hiện F27 - F28

F27 | Cấu hình release Android vẫn dùng khóa debug

P1 nếu phát hành; P2 cho demo • Xác định qua Gradle; chỉ build debug đã xác minh • Chủ trì đề xuất: B + C

Bằng chứng: Build type release tham chiếu signingConfigs.debug. APK đã chạy trong phiên trước là bản debug x86_64 phục vụ giả lập, chưa phải gói phát hành cho điện thoại ARM.

Tác động: Không phù hợp ký bản phát hành tin cậy hoặc tuyên bố đã sẵn sàng phân phối công khai. Không suy ra rằng mọi release build đều thất bại.

Cách sửa: Nếu chỉ thi demo: ghi rõ debug/emulator. Khi phát hành: dùng keystore riêng ngoài Git, quản lý secret CI, cấu hình API HTTPS và kiểm thử trên ABI thiết bị thật.

Nghiệm thu: Kiểm tra chứng thư APK release không phải debug; cài trên thiết bị mục tiêu, không cần Metro; không lộ signing password trong log.

mobile/android/app/build.gradle:131

F28 | SCA báo dependency cần phân loại và vá tương thích

P2 - chuỗi cung ứng • Đã chạy npm audit --omit=dev • Chủ trì đề xuất: D + B

Bằng chứng: Kết quả ngày 29/10/2026: 5 mục package bị ảnh hưởng, gồm 1 high và 4 low; hai advisory gốc nổi bật là body-parser và deepmerge. Các mục CLI có thể là ảnh hưởng dây chuyền, không phải 5 lỗ hổng độc lập.

Tác động: Cần xác định đường tiếp cận ở công cụ dev/Metro; kết quả audit chưa chứng minh khai thác được APK trên điện thoại. Không có kết quả SCA Maven đầy đủ trong lượt này.

Cách sửa: Đối chiếu advisory với lockfile, cập nhật bản vá tương thích, giới hạn cổng dev server. Không chạy audit fix --force hoặc hạ CLI 20.2 xuống 11.4.1 chỉ để làm báo cáo xanh.

Nghiệm thu: Chạy lại npm ci, audit, typecheck, Jest, Android debug sau cập nhật; lưu quyết định ngoại lệ có phạm vi và hạn. Bổ sung Maven/image scan trong repo security.

mobile/package-lock.json:4819

mobile/package.json:30

6. Phát hiện F29 - F30

F29 | Backend CI chỉ kiểm tra thư mục có tồn tại

P1 - thiếu cổng chất lượng • Xác định qua workflow • Chủ trì đề xuất: C + D

Bằng chứng: Job backend-ci-skeleton chỉ checkout, cài JDK 21 và test -d backend. Không chạy Maven build/test. Secret audit chỉ tìm tên .env/.key/.pem, không quét nội dung token trong tệp khác.

Tác động: Pipeline xanh không chứng minh backend biên dịch hoặc kiểm thử qua; cũng không đáp ứng Jenkins bắt buộc của mẫu môn Triển khai.

Cách sửa: Thêm Maven verify, báo cáo test/coverage, secret scan thực chất và SCA. Dùng Jenkins local làm pipeline nộp môn; GitHub Actions có thể giữ làm kiểm tra PR bổ sung.

Nghiệm thu: Cố ý tạo compile error/test fail trong nhánh thử: pipeline phải đỏ và không deploy. Chạy kiểm thử tích hợp có PostgreSQL/Testcontainers hợp lệ.

.github/workflows/ci.yml:45

F30 | Thiếu chuỗi triển khai bắt buộc của mẫu môn học

P0 - điều kiện nộp môn • Khoảng trống ở commit được cung cấp • Chủ trì đề xuất: C chủ trì

Bằng chứng: Không thấy Dockerfile, compose, Jenkinsfile, SonarQube hay cấu hình Prometheus/Grafana trong tracked source tại SHA này. pom có Actuator nhưng chưa có Prometheus registry; health không đồng nghĩa có metrics scrape.

Tác động: Chạy JAR/APK local chưa đạt yêu cầu đóng gói Docker của mẫu; thiếu Sonar/Jenkins và giám sát có ảnh hưởng điểm được ghi cụ thể trong tài liệu giảng viên.

Cách sửa: Ưu tiên Jenkins trên máy cá nhân, Docker Compose app+DB, Sonar tích hợp Jenkins và monitoring local. Thêm registry/exposure metrics đúng quyền, lưu cấu hình và ảnh chạy thật.

Nghiệm thu: Fresh checkout → pipeline local → quality gate → Compose healthy → smoke test; Prometheus target UP và Grafana có dữ liệu. Đây là kế hoạch, chưa được triển khai trong lượt audit.

backend/pom.xml:36

6. Phát hiện F31 - F32

F31 | Luồng hỗ trợ trên client chưa được hoàn thành

P1 - thiếu chức năng cốt lõi • Khoảng trống UI; không phải toàn backend vắng mặt • Chủ trì đề xuất: B chủ trì

Bằng chứng: Mobile đã có kiểu dữ liệu/API adapter cho service request nhưng màn ServiceRequestsScreen còn placeholder; phần quản trị/More còn giới hạn. Không thấy web frontend vận hành trong source; prototype thiết kế không phải web app hoàn chỉnh.

Tác động: Người dùng chưa thể demo trọn luồng đề tài chính bằng giao diện hiện có, dù backend đã có nhiều endpoint và mobile Project/Task đã phát triển đáng kể.

Cách sửa: Trong 2 tuần, chọn web tối thiểu cho requester/agent và tận dụng mobile Task hiện có; không làm đồng thời hai client đủ mọi tính năng. Xác nhận yêu cầu môn nâng cao với giảng viên.

Nghiệm thu: Một request được tạo, phân công, xử lý, từ chối/xác nhận từ UI với tài khoản khác nhau; không phải đổi trạng thái thủ công bằng DB để giả demo.

mobile/src/features/serviceRequests/screens/ServiceRequestsScreen.tsx:4

mobile/src/features/more/screens/MoreScreen.tsx:8

F32 | Thiếu hàng đợi hỗ trợ theo nhóm/phòng ban

P1 - khoảng trống thiết kế • Thiết kế hiện tại có chủ ý admin phân công • Chủ trì đề xuất: A + D

Bằng chứng: Chính sách hiện hành cho ADMIN phân công; danh sách request chủ yếu theo requester/assignee. ServiceCategory chưa gắn nhóm sở hữu, nên trưởng nhóm hỗ trợ không có hàng đợi riêng để triage.

Tác động: Admin trở thành nút thắt nghiệp vụ hàng ngày. Đây là thiếu sót so với mô hình doanh nghiệp đề xuất, không chứng minh mọi module hiện tại chỉ có luồng admin.

Cách sửa: Bổ sung ownerTeamId cho category và team hàng đợi; TEAM_LEADER chỉ được triage/assign trong team phụ trách, agent nhận việc theo assignment. Sửa canonical docs có phê duyệt phạm vi nhóm trước khi code.

Nghiệm thu: Trưởng nhóm IT nhìn/phân công ticket IT nhưng không ticket HR; EMPLOYEE không tự cấp quyền bằng cách đổi tham số teamId. Kiểm tra cùng chính sách ở query và mutation.

backend/src/main/java/com/worksphere/service_request/domain/ServiceCategory.java:19

backend/src/main/java/com/worksphere/service_request/application/ServiceRequestApplicationService.java:869

6. Phát hiện F33 - F34

F33 | Đổi mật khẩu chưa xác định xử lý các phiên khác

P2 - quyết định bảo mật • Xác định qua code; chính sách cần chốt • Chủ trì đề xuất: A + D

Bằng chứng: changePassword cập nhật passwordHash nhưng không thu hồi các refresh token/login session khác; resetPassword có nhánh thu hồi. Với F03, access token cũ còn sống đến hết hạn nếu không sửa filter.

Tác động: Nếu đổi mật khẩu do nghi bị lộ, một phiên khác vẫn có thể duy trì truy cập. Một số sản phẩm cố ý giữ phiên; cần ghi rõ lựa chọn thay vì coi đó luôn là lỗi khai thác.

Cách sửa: Đề xuất tùy chọn thu hồi các phiên khác, mặc định bật khi thay mật khẩu; giữ hoặc cấp lại phiên hiện tại theo hợp đồng. Kết hợp cơ chế revocation F03.

Nghiệm thu: Hai phiên A/B: đổi mật khẩu tại A và chọn thu hồi B thì access/refresh B đều bị chặn; A tiếp tục theo chính sách. Kiểm tra reset riêng.

backend/src/main/java/com/worksphere/identity/application/AuthApplicationService.java:330

F34 | Giới hạn phân trang chưa thống nhất

P2 - rủi ro tải và validation • Xác định tại controller dự án • Chủ trì đề xuất: A + D

Bằng chứng: getProjectMembers tạo PageRequest trực tiếp từ page/size do client gửi, không có mức tối đa như một số endpoint directory. Giá trị âm có thể đi vào lỗi kỹ thuật; size rất lớn tăng dữ liệu cần đọc.

Tác động: Người dùng hợp lệ có thể vô tình hoặc cố ý tạo truy vấn/trả payload quá lớn. Chưa chạy thử tải hoặc chứng minh một yêu cầu làm cạn tài nguyên.

Cách sửa: Chuẩn hóa PageRequest policy: page≥0, size 1..100 (mức đề xuất), whitelist sort; trả lỗi validation có cấu trúc. Không đổi quy ước page index mà không cập nhật client.

Nghiệm thu: page=-1/size=0 bị 400; size vượt trần bị từ chối hoặc clamp theo hợp đồng; request hợp lệ có kết quả đúng và ổn định.

backend/src/main/java/com/worksphere/project/web/ProjectController.java:170

7. Nghiệp vụ đúng nên bắt đầu từ đâu?

Phạm vi vừa sức là một doanh nghiệp duy nhất, vài phòng ban, nhiều nhóm làm việc và một cổng hỗ trợ chung. Không cần mô hình tập đoàn đa tenant hay microservice để thể hiện năng lực năm 2 chuẩn bị thực tập.

Khái niệm	Ý nghĩa / ví dụ
Phòng ban (Department)	Đơn vị tổ chức: IT, Nhân sự - Hành chính, Kinh doanh - Vận hành. Nhân viên có phòng ban chính; phòng ban không tự đồng nghĩa có quyền đọc mọi ticket.
Nhóm (Team)	Đơn vị nhận việc: IT Helpdesk, Hành chính hỗ trợ. Nhóm có leader và thành viên; nhóm hỗ trợ sở hữu một số category.
Dự án (Project)	Không gian mục tiêu và công việc có thời hạn, ví dụ “Chuẩn hóa máy tính nhân sự mới”. Thành viên có vai trò riêng trong dự án.
Yêu cầu hỗ trợ (ServiceRequest)	Nhu cầu của người gửi: tài khoản lỗi, máy hỏng, xin hỗ trợ thiết bị. Cần tiếp nhận, xử lý và được người gửi xác nhận.
Công việc (Task)	Đơn vị thực hiện nội bộ trong dự án: cài lại máy, kiểm tra VPN. Có assignee, tiến độ, review; không phải mọi task đều là ticket.
Tài khoản / quyền	Vai trò hệ thống cấp khả năng nền; membership và trạng thái tài nguyên quyết định được thao tác ở đâu.

Ví dụ: nhân viên Kinh doanh gửi “Không vào được VPN”, category “IT / Kết nối mạng” trỏ IT Helpdesk. Trưởng nhóm IT phân công kỹ thuật viên; kỹ thuật viên xử lý; chính người gửi xác nhận. Admin không phải người bấm thay mọi bước.

Quan hệ ticket và task

Về dài hạn, một ticket có thể sinh nhiều task kỹ thuật, nhưng ticket chỉ đóng sau nghiệm thu. Source hiện chưa có liên kết chuẩn Task-ServiceRequest; 14 ngày có thể demo hai phân hệ riêng và ghi rõ liên kết là backlog. Không thêm ràng buộc mới nếu chưa chốt hợp đồng và migration.

8. Vai trò, phạm vi dữ liệu và phân công

Người / vai trò	Được làm	Phạm vi
Nhân viên / requester	Tạo, xem, bổ sung, hủy OPEN; từ chối hoặc xác nhận kết quả; đánh giá sau đóng.	Ticket của mình; task trong dự án mình tham gia.
Kỹ thuật viên / agent	Nhận xử lý, cập nhật tiến độ/giải pháp, hỏi thêm thông tin.	Ticket được giao; không tự mở rộng sang toàn công ty.
Trưởng nhóm hỗ trợ / coordinator	Xem hàng đợi, triage, phân công/chuyển người trong nhóm, theo dõi tồn đọng.	Category/team phụ trách; không tự xem hàng đợi nhạy cảm khác.
Quản lý dự án / PM	Tạo/quản lý dự án theo phạm vi, thành viên, task và duyệt công việc.	Dự án mình quản lý; vai trò PM toàn cục không cho sửa mọi project.
Quản trị hệ thống / admin	Cấu hình tổ chức, tài khoản/quyền và danh mục; xử lý ngoại lệ có ghi lý do.	Quyền rộng nhưng thao tác đặc quyền phải audit; không dùng thay agent hàng ngày.

Requester và agent là vai trò nghiệp vụ trên từng ticket, không nhất thiết thêm hai role toàn cục mới. Một nhân viên có thể vừa gửi ticket cho HR vừa là agent nhận ticket IT. Không vì vậy mà được đọc tất cả ticket của hai phòng ban.

MVP có thể giữ bốn role SYSTEM_ADMIN, PROJECT_MANAGER, TEAM_LEADER, EMPLOYEE; bổ sung quyền coordinator qua TEAM_LEADER có kiểm tra ownership của team. Chỉ thêm SERVICE_COORDINATOR riêng khi thực sự cần và đã cập nhật tài liệu, seed và kiểm thử.

Nguyên tắc quyết định quyền

> Cho phép = tài khoản hoạt động + permission phù hợp + quan hệ với tài nguyên + trạng thái cho phép. Backend quyết định; giao diện dùng allowedActions/allowedTransitions để phản ánh cùng chính sách.

Danh sách người có thể phân công phải giới hạn nhóm và trạng thái ACTIVE. Thay team/category không được là cách vượt quyền bằng sửa UUID. Dữ liệu HR nhạy cảm nên dùng ví dụ giả và tách quyền ngay từ mô hình.

9. Luồng hỗ trợ trọn vòng và điểm kiểm soát

Bước / chuyển trạng thái	Người thực hiện	Điều kiện
Tạo → OPEN	Requester	Category hoạt động, nội dung đủ; asset/file liên kết hợp lệ. Hệ thống định tuyến về team theo category.
OPEN → ASSIGNED	Coordinator đúng team	Chọn agent ACTIVE; ghi assignment và history; một active assignee.
ASSIGNED → IN_PROGRESS	Assignee	Bắt đầu xử lý, ghi thời gian và thông báo phù hợp.
IN_PROGRESS → WAITING_FOR_USER	Assignee	Nêu rõ cần người gửi bổ sung điều gì; không tự đóng.
WAITING_FOR_USER → IN_PROGRESS	Assignee / quy tắc đã chốt	Requester bổ sung comment; MVP cho assignee tiếp tục sau khi nhận thông tin.
IN_PROGRESS → RESOLVED	Assignee	Bắt buộc có tóm tắt giải pháp; gửi thông báo đến requester.
RESOLVED → CLOSED	Requester	Xác nhận đã xử lý; người xử lý không nghiệm thu thay nếu khác requester.
RESOLVED → IN_PROGRESS	Requester từ chối	Bắt buộc lý do; cập nhật timestamp đúng nghĩa và thông báo assignee.
OPEN → CANCELLED	Requester	Hủy trước tiếp nhận theo MVP; lưu lý do/lịch sử.
CLOSED / CANCELLED	Không cho mutation vận hành	Không phân công lại; nhu cầu mới tạo request mới hoặc dùng lệnh reopen được thiết kế riêng sau này.

Các chuyển trạng thái phần lớn đã có trong enum; thay đổi trọng tâm là quyền từng bước, điều kiện và giao diện. Không đưa thêm trạng thái mới chỉ để làm sơ đồ đẹp. Chuyển nhóm sau ASSIGNED, hủy sau tiếp nhận và tự đóng sau timeout cần quy định riêng; chưa đưa vào MVP.

Luồng demo phải có nhánh trả lại: tạo → giao → xử lý → giải quyết → requester từ chối → xử lý lại → requester xác nhận. Mỗi bước dùng đúng tài khoản, có version và lịch sử, không sửa DB giữa buổi demo.

10. Luồng công việc và tình huống ngoại lệ

Task giữ luồng hiện có, sửa đúng phạm vi

PM tạo dự án và thêm thành viên; người có quyền tạo task; assignee thực hiện và đưa IN_REVIEW; người có quyền quản lý/review duyệt COMPLETED hoặc trả IN_PROGRESS. CANCELLED là trạng thái kết thúc theo chính sách. Cần chốt trường hợp PM cũng là assignee có được tự duyệt hay phải có reviewer khác.

Tình huống	Cách xử lý đề xuất cho MVP
Người xử lý nghỉ hoặc bị khóa	Coordinator chuyển assignment cho người ACTIVE cùng nhóm; giữ lịch sử, không sửa người đã xử lý trong dữ liệu cũ.
Sai category / sai nhóm	Requester chỉ sửa khi OPEN; coordinator chuyển nhóm là nghiệp vụ cần được kiểm soát, nếu chưa có thì dùng quản trị ngoại lệ có audit.
Hai người cùng cập nhật	Dùng version; một bên nhận 409 và tải lại, không ghi đè âm thầm. Assignment dùng khóa/unique hiện có.
Trưởng nhóm nghỉ	Bàn giao leader và quyền hàng đợi trong một giao dịch trước khi xóa membership.
File chưa liên kết / liên kết trái phép	Chỉ uploader và chính sách liên quan được phép; kiểm tra lại lúc attach, không chỉ lúc upload.
Dự án bị khóa/hoàn tất	Task và membership mutation phải theo chính sách trạng thái; quy định rõ thao tác lịch sử chỉ đọc.
Người gửi cũng là agent	Định nghĩa từ đầu: có thể xử lý ticket của mình trong demo đơn giản, nhưng nghiệm thu cần reviewer khác nếu yêu cầu độc lập.

Phân biệt phòng ban với quyền nghiệp vụ

Trưởng phòng Kinh doanh không mặc nhiên nhìn ticket mật của mọi nhân viên; trưởng nhóm IT cũng không nhìn ticket HR. Trong MVP, requester, active assignee, coordinator đúng team và admin có quyền được định nghĩa rõ. Báo cáo quản lý nên tổng hợp số lượng thay vì mở toàn bộ nội dung nhạy cảm.

11. Kiến trúc và dữ liệu cần chỉnh có kiểm soát

Thay đổi đề xuất	Tệp/lớp hoặc ràng buộc
Chính sách tập trung	ProjectPolicy, ServiceRequestPolicy, TaskPolicy, FileLinkPolicy; dùng chung cho query, mutation và allowedActions. Giữ controller mỏng.
Định tuyến hàng đợi	Thêm owner_team_id vào service_categories (hoặc bảng mapping nếu thật sự nhiều nhóm/category). MVP chọn một nhóm sở hữu mỗi category.
Bảo vệ session	Kiểm tra session còn sống; rotation refresh atomic; version/khóa cùng transaction. Index theo session/token hash hiện dùng.
Membership	Reactivate membership rõ nghĩa; khóa project khi thay PM; leader phải thuộc active team membership.
Audit tối thiểu	Writer/service cho audit_logs hiện có; actor/action/resource/outcome/correlationId; phân quyền đọc và bảo vệ dữ liệu nhạy cảm.
Nullable update	PATCH phân biệt absent/null cho task và liên kết asset; document bằng ví dụ request/response.
Hiệu năng	Batch counts task và giới hạn page/sort; đo trước/sau với số liệu demo có điều kiện rõ.
Metrics / readiness	Prometheus registry + exposure được bảo vệ; health DB/storage; log correlationId, không log token.

Hiện có migration đến V017. Thay đổi mới phải dùng số phiên bản tiếp theo chưa dùng, dự kiến V018+ sau khi kiểm tra nhánh thật. Không sửa migration đã chạy để làm lại lịch sử. Backfill category→team cho dữ liệu seed, kiểm tra bản ghi chưa có nhóm trước khi ép NOT NULL.

Triển khai an toàn với dữ liệu

Ưu tiên thay đổi cộng thêm, tương thích ngược trong đợt ngắn. Backup trước migration; kiểm thử restore trên DB riêng. Rollback image không tự rollback schema: nếu migration không tương thích, cần forward fix hoặc kế hoạch phục hồi dữ liệu đã thử, không chạy SQL đảo ngược tùy ý.

> Giữ modular monolith Spring Boot + PostgreSQL và một API hợp đồng. Không tách microservices, Kafka hay Kubernetes trong đợt 14 ngày này.

12. MVP vừa sức: làm gì, hoãn gì?

Bắt buộc trong đợt 14 ngày	Hoãn có ghi nhận
Auth chạy thật; logout/rotation và phạm vi project đúng	SSO, MFA, đa công ty/tenant, chính sách session nâng cao.
Seed 3 phòng ban, 2 nhóm hỗ trợ và tài khoản 4 tác nhân	UI CRUD tổ chức đầy đủ, import nhân sự hàng loạt, email invitation hoàn chỉnh nếu thiếu giờ.
Ticket tạo/giao/xử lý/chờ/từ chối/xác nhận; comment và history	SLA theo lịch làm việc, tự escalation đa cấp, chatbot/AI, báo cáo BI.
Web tối thiểu requester/agent; giữ mobile Project/Task đã có	Hai client ngang đủ tính năng; mobile Asset và ServiceRequest đầy đủ cùng lúc.
Jenkins local, Sonar gate, Docker Compose, Prom/Graf và ảnh minh chứng	Kubernetes, autoscale, triển khai nhiều vùng. SSH public là bonus sau khi phần bắt buộc đạt.
Test âm phân quyền, kiểm tra race token, backup/restore/rollback	Tuyên bố production-ready hoặc chịu hàng nghìn người dùng khi chưa đo.

Web nhỏ nhất để demo đúng nghiệp vụ

Một framework quen thuộc của nhóm, ưu tiên React/TypeScript nếu đã biết. Các màn: (1) đăng nhập, (2) yêu cầu của tôi + tạo, (3) chi tiết với comment/history/hành động, (4) hàng đợi agent/coordinator, (5) task list/detail tối thiểu hoặc điều hướng sang mobile hiện có. Quản trị danh mục/tổ chức dùng seed có tài liệu trong MVP.

Không hiển thị menu chưa làm như một chức năng hoạt động. Nếu không hoàn thành web kịp ngày 7, chọn hoàn thiện một client cho helpdesk và xác nhận lại yêu cầu môn nâng cao; không cố làm hai bản dở dang. Phải còn ít nhất một UI chứng minh trọn vòng hỗ trợ.

13. Môn Triển khai: yêu cầu phải bám sát

Mẫu người dùng gửi là cơ sở chính thức duy nhất đã có cho môn này. Mã Dxxx dưới đây là số thứ tự đoạn do quá trình trích xuất gán để truy vết, không phải số mục gốc của giảng viên.

Yêu cầu từ mẫu	Việc nhóm cần làm / hiện trạng
D048-D057: tổng quan, kiến trúc, yêu cầu hệ thống và sơ đồ CI/CD	Mô tả app/backend/DB, các bước pipeline và vai trò Jenkins/Sonar/Docker. Có tài liệu dự án nhưng cần viết đúng phiên bản demo.
D058: phần CI/CD tối đa 5 điểm	Không suy ra tổng điểm cả học phần chỉ từ mục này. Bám tiêu chí giảng viên và kết quả thực tế.
D059: Jenkins trên máy cá nhân	Cài/cấu hình tại máy dùng thi; chụp cấu hình node/tools và pipeline chạy. GitHub Actions không thay thế điều kiện này.
D060: khuyến khích Jenkinsfile	Đưa Jenkinsfile vào repo triển khai để review, chạy lại và truy vết theo commit.
D061: SonarQube tích hợp Jenkins bắt buộc; thiếu -1	Có stage phân tích và chất lượng; ảnh dashboard liên hệ đúng project/SHA. Không chỉ chụp trang chủ Sonar.
D062: Docker/docker-compose bắt buộc; không đóng gói được → trượt	Build image backend/web, Compose app+PostgreSQL, health và volume. Việc chạy JAR hoặc giả lập không thay thế mục này.
D063-D064: ảnh thật, gộp một quyển; copy kết quả có thể cả hai trượt	Ảnh do nhóm tự chạy, có build ID/commit/thời điểm, che secret. Không dùng ảnh báo cáo lịch sử hoặc ảnh của bạn khác làm kết quả mới.

Ưu tiên điểm và rủi ro: Docker chạy thật, Jenkins cá nhân và Sonar được tích hợp là phần phải bảo đảm trước khi dành công cho server public. Báo cáo này chưa phải quyển minh chứng kết quả triển khai đã thực hiện.

14. Giám sát, bonus và bộ ảnh minh chứng

Nội dung trong mẫu	Cách triển khai và chứng minh
D065-D069: pipeline deploy SSH lên server public	Làm sau phần local; pipeline tương tự, đổi stage deploy để chạy compose qua SSH. Phải có URL public hoạt động. Thành công +1 theo mẫu; không làm được public nhưng local đạt thì giữ phần điểm local.
D070-D075: Prometheus và Grafana	Bắt buộc phần monitoring local theo mẫu; không bắt buộc đưa monitoring lên public. Thiếu phần này bị -1. Cần mô tả cấu phần, cách cài, ảnh target và dashboard có dữ liệu.
D076-D079: kết luận/cải tiến	Nêu điều đã làm, hạn chế và cải tiến phần mềm/pipeline. Không trình bày kế hoạch chưa làm thành kết quả đã đạt.
D003, D007-D008: phân công và đánh giá	Điền tên/MSSV thật, việc có bằng chứng và tự đánh giá. Mẫu ghi tự đánh giá 30%, giảng viên 70%; không tự ghi tất cả 10 khi chưa đối chiếu đóng góp.

Danh sách ảnh nên có trong quyển riêng của nhóm

• Jenkins trên máy cá nhân: phiên bản, node/tools và toàn pipeline cùng build ID, SHA nguồn.

• Sonar project đúng commit, quality gate và Jenkins nhận kết quả gate; thêm một build thất bại có chủ ý để chứng minh cổng chặn.

• Docker image/tag, compose services healthy, ứng dụng đăng nhập và luồng ticket chạy trên bản deploy.

• Prometheus target UP; Grafana có request rate/error/latency hoặc JVM; tự tạo vài request để có dữ liệu thật.

• Backup + restore DB thử riêng, rollback image về tag trước và smoke test; SSH public/HTTPS nếu làm bonus.

Mỗi ảnh nên có chú thích: mục đích, thao tác, kết quả, ngày giờ, người thực hiện và commit/image. Ảnh console phải che credentials. Không chỉnh ảnh để biến lỗi thành PASS.

15. Pipeline local đề xuất để triển khai thật

Stage theo thứ tự	Đầu ra / điều kiện chặn
1. Checkout đúng version	Repo triển khai ghi APP_COMMIT và SECURITY_COMMIT. Checkout app vào thư mục app; từ chối ref không hợp lệ, không dùng main trôi nổi.
2. Kiểm tra và build	JDK mục tiêu 21; Maven wrapper verify và báo cáo test; Node theo .node-version, npm ci, lint/typecheck/Jest cho phần thay đổi.
3. Kiểm thử tích hợp	PostgreSQL đúng engine bằng Testcontainers/Docker trên node; không coi H2 thay được mọi unique/index/locking PostgreSQL.
4. Phân tích / scan	JaCoCo + Sonar analysis; secret scan/SCA từ repo security; lưu báo cáo cùng build. Gate đề xuất áp dụng code mới, không tự nhận là ngưỡng giảng viên.
5. Quality gate	Jenkins chờ Sonar qua webhook; timeout rõ; gate không đạt thì dừng deploy.
6. Build image	Dockerfile trong repo app; tag theo SHA, lưu image digest; backend runtime không chứa compiler/secret; web build riêng nếu có.
7. Compose local + smoke	DB healthy rồi app ready; migration, đăng nhập, tạo/đọc ticket; dừng nếu health hoặc smoke fail. Không xóa volume để chữa lỗi.
8. Monitoring / lưu bằng chứng	Prom scrape app, Grafana có dữ liệu; archive test/log/manifest đã che secret. Chỉ deploy bản vừa được kiểm tra.

Sonar Jenkins integration cần cấu hình server/token credential và webhook về Jenkins; dùng withSonarQubeEnv và waitForQualityGate theo tài liệu chính thức [S3]. Credentials lưu trong Jenkins, không chép vào Jenkinsfile. Sử dụng nguyên tắc pipeline được quản lý trong Git [S2].

Trên Windows nên dùng Jenkins node nhất quán với Docker Desktop/WSL2 hoặc agent Linux phù hợp; kiểm tra tài nguyên trước. Sonar + Android emulator + DB + Jenkins có thể nặng, nên tắt giả lập do nhóm mở khi không dùng, không can thiệp ứng dụng cá nhân khác.

16. Môn An toàn thông tin làm thế nào?

Lấy chính hệ thống helpdesk làm đối tượng kiểm chứng an toàn. Mục tiêu là chỉ ra tài sản cần bảo vệ, mối đe dọa, biện pháp kiểm soát và kết quả trước/sau. Chưa có rubric môn này, nên đây là gói nội dung đề xuất để hỏi giảng viên ngay ngày 1.

Nội dung đề xuất	Sản phẩm và ví dụ kiểm chứng
Mô hình đe dọa	DFD: web/mobile → API → DB/storage; ranh giới tin cậy; STRIDE cho token, ticket HR, file và pipeline. Nêu tác nhân và giả định.
Xác thực và session	BCrypt, token hash, TTL, logout/revocation, rotation single-use. Dùng F03/F04 làm ca trước/sau an toàn ở local.
Phân quyền	Ma trận requester/agent/coordinator/PM/admin; test PM A không sửa B, IT không xem hàng đợi HR, employee không gán role.
Bảo vệ dữ liệu và file	HTTPS trên môi trường public; secret không vào Git; kiểm tra liên kết file/asset, dung lượng và path traversal; dữ liệu demo giả.
Truy vết / kiểm thử	Audit actor-action-outcome; test đầu vào sai, token cũ, quyền thiếu, xung đột. Không log password/token.
Chuỗi cung ứng	npm/Maven/image scan + SBOM nếu kịp; phân loại khả năng ảnh hưởng, không chỉ đếm cảnh báo; quản lý ngoại lệ có hạn.
Báo cáo xử lý	Finding có bằng chứng, mức ảnh hưởng, cách sửa, regression test; ghim đúng APP_COMMIT/image digest. Dùng OWASP ASVS làm khung tham khảo, không tự nhận đạt chứng nhận.

Phạm vi thực hành: chỉ test trên local hoặc hệ thống nhóm được quyền kiểm thử; dùng fixture/tài khoản riêng, không đính kèm token thật. Chọn 3-5 ca có giải thích sâu và bằng chứng trước/sau thay vì liệt kê nhiều kiểu tấn công không liên quan.

Nguồn hướng dẫn: OWASP Authorization nhấn mạnh kiểm tra quyền trên mỗi request và dựa quan hệ/thuộc tính tài nguyên [S5]; ASVS cung cấp khung yêu cầu kiểm chứng [S6]. Đây không phải yêu cầu chính thức tự động áp cho môn học.

17. Môn Kỹ năng lập trình nâng cao làm thế nào?

Chọn các kỹ thuật thể hiện được bằng code và test trong sản phẩm đang có. Trọng tâm là thiết kế, xử lý lỗi, giao dịch/concurrency, tái sử dụng và kiểm thử. Việc có web hay mobile phải đối chiếu yêu cầu giảng viên; số lượng màn hình không tự chứng minh kỹ năng nâng cao.

Kỹ thuật / năng lực	Ứng dụng cụ thể và bằng chứng
OOP và thiết kế miền	Entity giữ invariant; policy tách khỏi controller; không nhét mọi quyền vào if trong UI. ADR giải thích lựa chọn modular monolith.
Hợp đồng và kiểu dữ liệu	DTO validation, error catalog, TS runtime guard, nullable PATCH; contract test backend-client.
Giao dịch / xử lý đồng thời	Rotation refresh atomic, assignment unique, optimistic version khi sửa ticket, khóa project khi giữ PM cuối; integration test race.
Tái sử dụng có kiểm soát	Policy dùng chung allowedActions/mutation; batch mapping; component màn chi tiết và hooks tránh lặp; tránh abstraction quá mức.
Xử lý lỗi và tài nguyên	503/403/409 nhất quán; fail closed khi tra cứu quyền lỗi; file/DB compensation và cleanup.
Kiểm thử và chất lượng	Unit test quy tắc, integration PostgreSQL, UI tương tác chính; coverage vùng code mới và review PR; không lấy 796 test làm bằng chứng mọi nghiệp vụ đã đúng.
Tích hợp nhiều client nếu cần	Web tối thiểu và mobile cùng API/version; chứng minh một thay đổi trạng thái từ client A được client B đọc đúng.

Cách báo cáo có sức thuyết phục

Chọn 2-3 ví dụ trước/sau: thiếu quyền theo project → policy + test âm; refresh race → giao dịch atomic + test đồng thời; biểu mẫu không xóa được deadline → hợp đồng PATCH rõ ràng + test client/server. Mỗi ví dụ giải thích lý do, đánh đổi và kết quả thật.

Nếu giảng viên yêu cầu thêm generic, collection, stream, đa luồng hoặc pattern cụ thể, ánh xạ vào phần đang dùng; không nhồi pattern chỉ để đủ tên. Xác nhận đề cương ở ngày đầu, không đợi hoàn thiện xong mới hỏi.

18. Tách thành ba GitHub repo cho đúng

Repository đề xuất	Nội dung chính / học phần
worksphere-app	Nguồn chuẩn duy nhất của backend, web tối thiểu, mobile hiện có, migrations, Dockerfiles, API contract, unit/integration/UI tests và thiết kế. Dùng làm bài Kỹ năng lập trình nâng cao.
worksphere-security	Threat model, ma trận quyền, test an toàn bằng fixture, SAST/SCA/secret scan config, báo cáo trước/sau, quyết định xử lý advisory và bằng chứng. Dùng cho An toàn thông tin.
worksphere-deployment	Jenkinsfiles, compose local/public, cấu hình Sonar/Prom/Graf, script health/smoke/backup/restore/rollback, runbook và quyển ảnh kết quả thật. Dùng cho Triển khai phần mềm.

Ba repo có ba loại code và bằng chứng khác nhau nhưng dùng chung một sản phẩm. Security test code gọi API hoặc chạy trên fixture của app; deployment code đóng gói/triển khai app. Không copy toàn backend thành ba phiên bản độc lập để “đủ ba môn”.

Quy tắc đồng bộ phiên bản

• App phát hành tag, ví dụ v0.1.0-rc1; deployment ghi APP_COMMIT đầy đủ và image digest; security ghi TARGET_APP_COMMIT và kết quả kiểm thử chính bản đó.

• Lỗi nghiệp vụ được sửa trong worksphere-app; security/deployment cập nhật commit pin sau khi kiểm tra. Không sửa source đã copy lén trong pipeline workspace.

• Nếu môn bắt buộc source tự chứa trong repo nộp, cung cấp source archive từ đúng tag và provenance hoặc submodule ghim commit theo yêu cầu giảng viên; tránh duy trì thêm business fork.

• Mỗi repo có README riêng: mục tiêu môn, cách chạy, người đóng góp, commit nguồn, giới hạn và đường dẫn minh chứng. Link chéo rõ ràng để người chấm đi theo được.

Tên repo là gợi ý, chưa tạo hoặc push repo trong lượt lập báo cáo này. Không cần gọi API tạo GitHub repository để lập kế hoạch.

19. Cấu trúc repo và giao ước release

Repo / thư mục	Vai trò
app: backend/, web/, mobile/	Code ứng dụng. Dockerfile đặt cạnh context build tương ứng; không để source chính phụ thuộc repo infrastructure để biên dịch.
app: docs/, contracts/, tests/	Scope ba môn đã thống nhất; kiến trúc, role/state matrix, API, fixtures và hướng dẫn đóng góp; ghi rõ phần mobile kế thừa.
security: threat-model/, policies/, tests/	DFD/STRIDE, authorization.csv, các test âm gọi API local; runner đọc địa chỉ và credential từ biến môi trường.
security: scans/, findings/, evidence/	Config scanner; báo cáo theo SHA; chỉ bằng chứng đã che secret. Không commit output nhạy cảm hay database dump.
deployment: jenkins/, compose/, monitoring/	Jenkinsfile.local/public, compose app/DB và monitoring, dashboard Grafana dạng JSON, cấu hình scrape.
deployment: scripts/, runbooks/, evidence/	Smoke, backup/restore, rollback, hướng dẫn tái lập và ảnh tự chụp; .env.example chỉ tên biến/giá trị giả.
deployment: versions.env hoặc release-manifest	APP_COMMIT, SECURITY_COMMIT, image digest, migration version, ngày build. Đây là metadata công khai, không chứa password.

Jenkins checkout repo app vào workspace/app ở đúng APP_COMMIT. Compose trong repo deployment tham chiếu image digest hoặc build context workspace/app/backend và workspace/app/web với Dockerfiles của app. Ghi rõ đường dẫn chuẩn để fresh checkout không phụ thuộc ổ D: của tác giả cũ.

Lịch sử và công lao

Giữ lịch sử/provenance source gốc và kiểm tra LICENSE/quyền dùng lại trước khi phát hành. Mobile của nhóm bạn là thành phần dùng chung; báo cáo chỉ ghi phần bốn thành viên thực sự sửa/kiểm thử, không nhận toàn bộ mobile là công sức của nhóm ba môn. Cần xác nhận giảng viên cho phép chung đề tài và thành phần giữa các nhóm.

Tài liệu 07_FOUR_COURSE_MATRIX đang thuộc bối cảnh bốn môn của tác giả gốc; không phải rubric An toàn thông tin của nhóm này. Tạo ma trận ba môn mới sau khi thống nhất, không chỉ đổi tiêu đề bìa rồi giữ nguyên nội dung.

20. Chia việc cho bốn người và ngân sách giờ

Thành viên tạm ký hiệu	Trách nhiệm chính	Người review
A - backend/nghiệp vụ	Policy, auth/refresh, request transitions, queue query và migration; tích hợp code lõi.	D kiểm tra quyền; B đối chiếu API
B - client/tích hợp	Web requester/agent nhỏ, đối chiếu mobile hiện có, UI trạng thái và lỗi; demo luồng.	A kiểm tra hợp đồng; D test UI
C - triển khai	Jenkins cá nhân, Docker/Compose, Sonar, Prom/Graf, backup/rollback và evidence.	A kiểm tra cấu hình app; D secret/scan
D - an toàn/QA/tài liệu	Threat model, test âm/race, audit/SCA phối hợp A, báo cáo và thu minh chứng, điều phối test.	A/C review script; cả nhóm duyệt báo cáo

Giả định mỗi người dành 2,5-3 giờ/ngày trong 14 ngày: tổng khoảng 140-168 giờ người. Đây là giả định lập kế hoạch, chưa phải giờ đã xác nhận. Dành 20-25% cho tích hợp, sửa lỗi và báo cáo; sức phát triển thực tế khoảng 105-134 giờ người.

Nề nếp làm việc tối thiểu

• Mỗi ngày 15 phút: hôm qua xong gì, hôm nay bàn giao gì, vướng gì; dùng board To do / Doing / Review / Done với tiêu chí Done cụ thể.

• PR nhỏ theo từng issue; A sở hữu policy/migration, B client, C hạ tầng, D test/security. Một người ghi một file tại một thời điểm; review trước khi ghim release.

• Không để C chờ app hoàn tất: từ ngày 1 dùng backend hiện có để dựng pipeline, rồi cập nhật image sau. D viết test âm và fixture trước khi A sửa.

• Tất cả bốn người phải tự chạy được luồng demo và giải thích một lỗi đã sửa, một lựa chọn thiết kế, một kết quả kiểm thử; không chia ba môn thành ba người hiểu riêng từng phần.

Giới hạn giờ: nếu khả năng thực tế thấp hơn giả định, cắt tính năng phụ trước. Không cắt điều kiện Docker/Sonar của mẫu hoặc bỏ test phân quyền để giữ thêm màn hình.

21. Lịch 14 ngày: tuần thứ nhất

Mốc bắt đầu 29/10/2026 theo ngày hiện tại. Kết thúc kế hoạch 11/11/2026; chuẩn bị cho giai đoạn thi khoảng 12/11. Đây là lịch làm việc đề xuất, không khẳng định ngày nộp chính thức.

Ngày	A / B	C / D và cổng bàn giao
D1 • 29/10	A: chốt roles/state, baseline/patch. B: kiểm API, dựng web shell/login.	C: kiểm Docker/Jenkins và tài nguyên. D: đối chiếu rubric hai môn còn thiếu, fixture và test plan. Chốt MVP/ownership.
D2 • 30/10	A: F03/F04/F05. B: login/me, danh sách của tôi.	C: build backend image, compose DB/app. D: test âm auth/project trước-sau; review bản vá.
D3 • 31/10	A: policy requester/assignee và queue team tối thiểu. B: create/detail request.	C: Jenkins checkout/build, Sonar server/plugin/webhook. D: seed 4 tác nhân, ma trận quyền và testcase.
D4 • 01/11	A: F06/F07/F08, history/timestamp. B: hành động cancel/resolve/confirm/reject.	C: compose health/volume; D: integration request, kiểm tra terminal và tài sản trái quyền.
D5 • 02/11	A: queue read/assign scope; sửa F09/F14/F19 liên quan. B: coordinator/agent queue.	C: chất lượng build/test/Sonar; D: notification reject/audit tối thiểu phối hợp A.
D6 • 03/11	A+B: tích hợp nhiều tài khoản, fix lỗi hợp đồng; giữ Task mobile chạy.	C: smoke trên Compose. D: test hồi quy và bằng chứng hai vòng xử lý, không sửa DB giữa demo.
D7 • 04/11	Cả nhóm demo một ticket từ đầu đến đóng và nhánh từ chối. Không thêm tính năng lớn.	Go/no-go: nếu luồng chưa xong, bỏ asset/UI phụ và thu nhỏ web; vẫn giữ một UI trọn vòng.

D2-D4 là vùng có rủi ro quá tải cho A. D cần viết fixture/test và audit helper; C giải quyết cấu hình runtime; B chủ động mock theo hợp đồng đã chốt để không ngồi chờ. Nếu A bị chậm, ưu tiên khóa quyền và state transitions, cắt sửa tối ưu không đụng demo.

22. Lịch 14 ngày: tuần thứ hai

Ngày	Công việc chính	Kết quả cần nhìn thấy
D8 • 05/11	C chủ trì hoàn thiện Maven verify, report/coverage, Sonar quality gate, build image và deploy local; A/B sửa lỗi gate thật.	Jenkins trên máy cá nhân chạy một bản nguồn đã ghim; gate fail phải chặn deploy.
D9 • 06/11	C: Prometheus/Grafana; A thêm registry/readiness; D kiểm tra metric không lộ dữ liệu.	Target UP, dashboard có request/latency/error/JVM; đủ ảnh monitoring local.
D10 • 07/11	D: SCA/secret/negative tests; A/B sửa các lỗi ưu tiên; cập nhật báo cáo trước/sau.	F03/F04/F05/F06/F07/F08 có bằng chứng hoặc trạng thái còn tồn rõ; không ghi PASS khi chưa chạy.
D11 • 08/11	C+D: backup, restore sang DB thử riêng, rollback image; A xác nhận schema tương thích.	Dữ liệu khôi phục kiểm tra được, có thời gian đo thật; runbook không xóa volume đang dùng.
D12 • 09/11	Nếu phần bắt buộc đã đạt: C làm SSH public/HTTPS; A/B/D đóng lỗi và viết tài liệu.	URL public là bonus. Nếu local/monitoring chưa đạt thì bỏ public và hoàn thiện bắt buộc.
D13 • 10/11	Cả nhóm hoàn thiện ba báo cáo/README, bảng phân công, quyển ảnh triển khai; rehearsal thay người thuyết trình.	Tài liệu, app SHA, security target và image digest khớp; ảnh tự chụp đã che secret.
D14 • 11/11	Buffer lỗi P0/P1, fresh checkout thử lại, đóng release candidate và lưu bản dự phòng.	Không đổi framework/schema lớn; demo khởi động được theo runbook, mỗi người giải thích được đóng góp.

Điểm dừng tính năng: hết D7 đóng phát triển mới; sau D10 chỉ sửa lỗi, chạy lại phần bị ảnh hưởng và hoàn thiện minh chứng. Mọi đề xuất lớn còn lại đi vào backlog sau thi.

23. Backlog tối thiểu và ước lượng thực tế

Gói việc ưu tiên	Người / giờ người	Phụ thuộc / tiêu chí xong
B01 baseline, scope, fixture, hợp đồng	A+D / 7-9	Có ma trận vai trò/trạng thái, dữ liệu demo giả và patch F01/F02 được review.
B02 auth + quyền theo project	A+D / 13-17	F03/F04/F05; test âm/race qua PostgreSQL; không còn đường sửa project ngoài phạm vi.
B03 ticket policy + queue tối thiểu	A+D / 16-20	F06/F07/F08/F17/F18/F32; team seed và query scope; history đúng.
B04 web tối thiểu + kết nối mobile cũ	B / 20-25	UI trọn vòng ticket; không yêu cầu hai client ngang đủ tính năng.
B05 Jenkins/Compose/Sonar/monitoring	C+A / 20-25	Pipeline local thật và đủ bằng chứng mẫu môn.
B06 audit/security smoke/scan	D+A / 10-13	Audit các thao tác demo; test âm ưu tiên; scan phân loại advisory.
B07 restore/rollback, tài liệu, rehearsal	C+D+cả nhóm / 14-18	Runbook thử được, ba repo/README/pin rõ, báo cáo theo môn.
Dự phòng/tích hợp	Cả nhóm / 24-35	Sửa lỗi giữa các gói, cổng chất lượng, thiết bị và thu ảnh thật.

Tổng dải ước lượng 124-162 giờ người, có dự phòng; chỉ phù hợp khi nhóm dùng lại source và công nghệ quen thuộc. Các khoảng giờ là dự toán, không phải cam kết. Không cộng thêm toàn bộ F01-F34 như các việc bắt buộc riêng rẽ: nhiều mục nằm chung gói, một số hoãn.

Các mục hoãn có trách nhiệm

Email onboarding/reset hoàn chỉnh nếu không nằm rubric bắt buộc; full Team/Admin UI; tối ưu N+1 sâu; quản lý tài sản mobile đủ; liên kết ticket-task; SLA/escalation và phân tích nâng cao. Ghi hạn chế trong báo cáo và ẩn/ghi rõ menu chưa làm, không giả kết quả.

24. Bộ tiêu chí nghiệm thu và kiểm thử ưu tiên

Mã / kịch bản	Kỳ vọng sau sửa
T01 auth startup/login	Dev seed idempotent; login/me hợp lệ; ACTIVE mới có session; mật khẩu sai lỗi chung.
T02 logout / rotation	Access token đã logout bị 401 theo chính sách chọn; hai refresh cùng token chỉ một thành công.
T03 project isolation	PM A không sửa B, không thêm mình vào B; PM B được thao tác; không dùng UI ẩn nút làm bằng chứng duy nhất.
T04 requester lifecycle	Requester hủy OPEN; requester xác nhận RESOLVED; người ngoài không thao tác; assignee không tự xác nhận thay.
T05 terminal / concurrency	CLOSED/CANCELLED không reassign; version cũ nhận 409; một active assignment; history không trùng khi retry.
T06 queue / privacy	Coordinator IT chỉ nhìn/assign trong IT; HR tách dữ liệu; assignee/requester thấy đúng request của mình.
T07 asset/file links	Sửa asset sang của người khác bị chặn; file sai purpose/uploader không attach; lỗi DB quyền không trả nội dung.
T08 task/data consistency	Re-add membership active lại; allowedActions đúng quyền; clear deadline thật sự null; số đếm không sai.
T09 deployment gates	Jenkins verify/Sonar/gate/image/Compose/smoke; gate đỏ không deploy; DB/storage volume giữ dữ liệu khi restart.
T10 monitoring / recovery	Prom UP, Grafana có dữ liệu; restore DB riêng; rollback image tương thích; ghi thời gian thực đo.

T01 một phần đã có bằng chứng; T02 hiện tái hiện lỗi, chưa PASS sau sửa; các T03-T10 là tiêu chí triển khai kế tiếp. Bộ test hiện có cần được bổ sung tại những khe hở này. Báo cáo không gắn nhãn xanh cho các tiêu chí mới chỉ được thiết kế.

Không cần lập test cho mọi thay đổi trình bày nhỏ. Ưu tiên integration test có ý nghĩa cho quyền, state, transaction, PostgreSQL constraint và đường chạy end-to-end; chỉ chạy lại toàn suite khi thay đổi hoặc lỗi mới đòi hỏi.

25. Kịch bản bảo vệ bài trong 10-12 phút

Thời lượng	Thao tác / người trình bày
0-1 phút	Nêu vấn đề nội bộ, ba phòng ban/nhóm, vai trò và phạm vi MVP; chỉ ra ba repo cùng target app version.
1-4 phút	B dùng requester tạo lỗi VPN. A dùng coordinator IT phân công; agent xử lý và RESOLVED. Requester từ chối rồi xác nhận sau lần xử lý tiếp.
4-6 phút	D chứng minh một ca cấm: PM ngoài dự án hoặc IT đọc HR bị từ chối; trình bày kết quả refresh/logout trước-sau và audit che dữ liệu.
6-9 phút	C cho thấy Jenkins máy cá nhân, build ID/commit, Sonar gate, image digest và Compose healthy; không chỉ chạy video/ảnh thay ứng dụng.
9-10 phút	C mở Prom target UP/Grafana; giải thích một chỉ số và kết quả restore/rollback thực đo.
10-12 phút	Mỗi người nêu một đóng góp có PR/test; kết luận giới hạn: mobile kế thừa, module hoãn, public bonus nếu đã làm thật.

Dữ liệu demo nhỏ nhưng có phân biệt quyền

Dùng 3 phòng ban, 2 nhóm hỗ trợ, một project IT và một project khác để kiểm tra chéo; tối thiểu requester, coordinator IT, agent IT, admin và một tài khoản ngoài phạm vi. Nhóm có bốn người không có nghĩa chỉ có bốn tài khoản demo: một người có thể mở nhiều profile kiểm thử riêng.

Chọn dữ liệu giả: lỗi VPN, máy in, yêu cầu hỗ trợ thiết bị; tránh hồ sơ y tế/lương hoặc dữ liệu thật. Chuẩn bị trạng thái trước demo bằng seed có tài liệu, nhưng các bước trình diễn phải qua API/UI thật.

Chuẩn bị dự phòng: runbook khởi động, bản image/tag đã kiểm tra, DB demo backup và ảnh thật đã thu. Nếu mất Internet, demo local vẫn thể hiện phần bắt buộc. Không lấy ảnh làm bằng chứng rằng một chức năng chưa chạy đã thành công.

26. Rủi ro và lộ trình sau giai đoạn thi

Rủi ro	Giảm thiểu / quyết định
Mẫu hai môn còn thiếu	Ngày 1 xác nhận rubric, web/mobile, kỹ thuật cần chứng minh và việc dùng chung sản phẩm/nhóm. Điều chỉnh phần chuyên môn, giữ baseline.
Máy Windows thiếu tài nguyên/công cụ	Kiểm tra Docker/Jenkins sớm; cố định toolchain; không chạy emulator cùng mọi dịch vụ nếu quá nặng. Dùng node/agent nhất quán.
Bạn trong nhóm đóng góp ít / phụ thuộc một người	Issue nhỏ có chủ và người review; kiểm tra hàng ngày bằng PR/test/evidence; chuyển việc sớm thay vì đợi tuần cuối.
Scope quá lớn	Cắt asset UI, nâng cao SLA, full admin và client parity; không cắt auth/RBAC hoặc Docker bắt buộc.
Khác phiên bản giữa ba repo	Release manifest ghim SHA/digest và migration; evidence ghi target cụ thể; không ghi “latest” làm mốc nghiệm thu.
Bản quyền và công lao	Giữ nguồn gốc, kiểm tra quyền dùng source, ghi thành phần kế thừa; hỏi giảng viên quy định dùng chung đề tài.
Đưa demo lên public còn lỗ hổng	Chỉ public sau test phân quyền và secret/config; dùng dữ liệu giả, HTTPS, tắt seed và bảo vệ công cụ quản trị.

Sau thi: thêm 4-6 tuần nếu tiếp tục làm portfolio

Tuần 1-2: hoàn thiện onboarding/email, quản trị team, audit và các lỗi P2 còn lại. Tuần 3-4: liên kết ticket-task, UI tài sản cơ bản, SLA có lịch làm việc, thông báo đầy đủ. Tuần 5-6: đo tải, tối ưu truy vấn, restore drill, đánh giá quyền/riêng tư và tài liệu vận hành. Các mốc là đề xuất, không được gộp vào cam kết hai tuần hiện tại.

Một bài tốt ở mức năm 2 là phạm vi rõ, luồng đúng, code giải thích được, test có ý nghĩa và triển khai tái lập được. Không cần mô phỏng mọi quy trình doanh nghiệp lớn để chứng minh năng lực.

27. Tài liệu tham chiếu và dấu vết kiểm tra

[S1] Mã nguồn WorkSphere tại commit audit. Bằng chứng từng phát hiện đã gắn link theo file/dòng; có thể bấm trực tiếp trong PDF.

[S2] Jenkins: Using a Jenkinsfile. Quản lý pipeline trong Git, build/test/deploy và xử lý credentials.

[S3] SonarQube: Jenkins pipeline pause / quality gate. Tích hợp quality gate, webhook và bước chờ kết quả trong Jenkins.

[S4] Spring Boot: Metrics. Micrometer registry/Prometheus và cấu hình metrics; không suy ra Actuator mặc định đã có scrape endpoint.

[S5] OWASP: Authorization Cheat Sheet. Least privilege, quyền theo quan hệ tài nguyên, kiểm tra mỗi request và xử lý lỗi an toàn.

[S6] OWASP ASVS. Khung tham khảo kiểm chứng an toàn ứng dụng; không phải chứng nhận đạt chuẩn.

[S7] Docker Compose: Production. Tách cấu hình triển khai, môi trường và vận hành Compose.

[S8] Advisory body-parser. Tham chiếu kết quả npm audit high; cần đánh giá đường tiếp cận thực tế.

[S9] Advisory deepmerge. Tham chiếu kết quả npm audit và ảnh hưởng dây chuyền đến CLI.

Nguồn học phần: Mẫu báo cáo Trien khai phan mem.docx trong thư mục Downloads do người dùng cung cấp; đã đọc 79 đoạn/bảng trích xuất. Các dòng D059-D075 là cơ sở phân biệt bắt buộc/bonus. Các đề xuất khác không được diễn giải thành yêu cầu giảng viên.

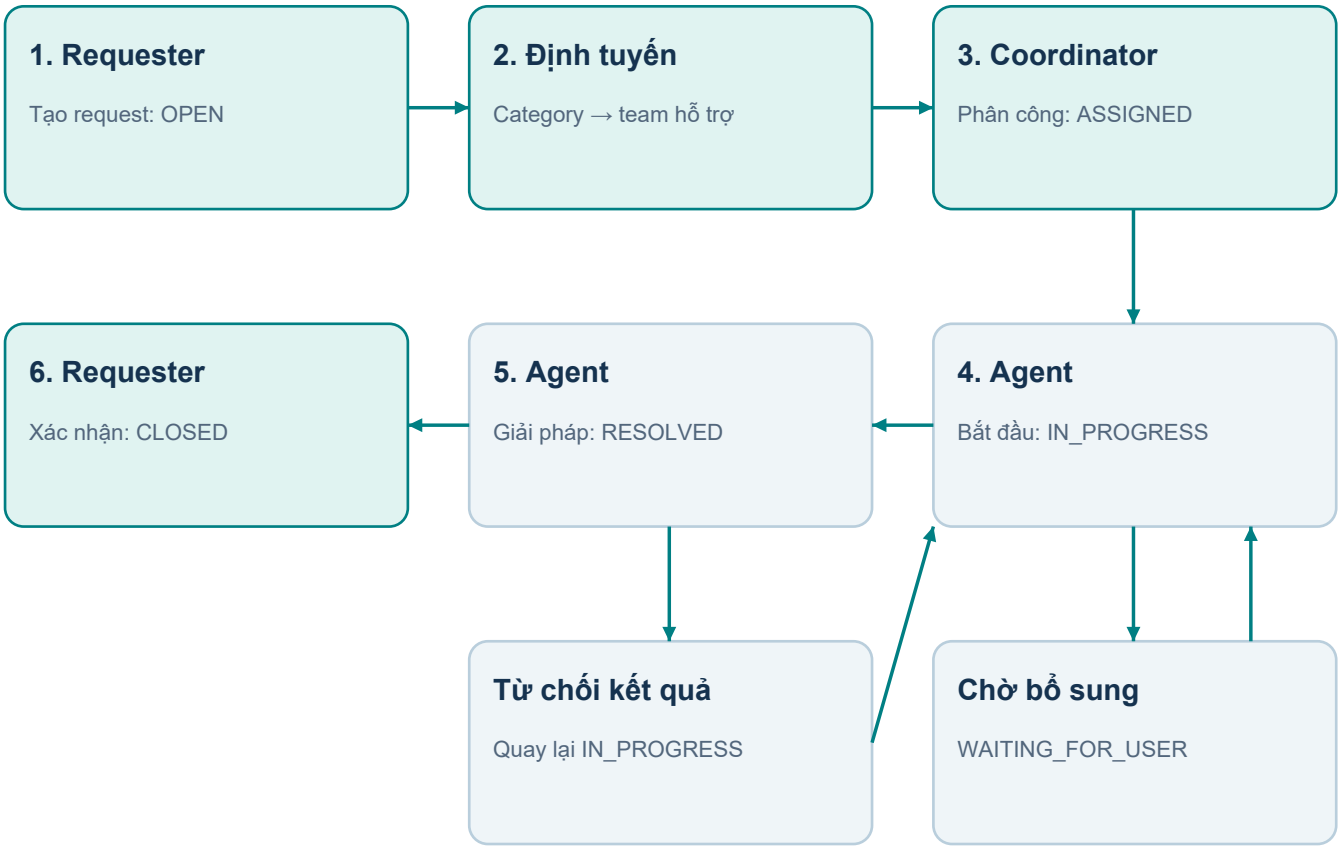
Tài liệu kỹ thuật trực tuyến được đối chiếu ngày 29/10/2026. Phiên bản trang docs có thể mới hơn dependency của app; khi triển khai phải kiểm tra tương thích cụ thể với lockfile/pom của phiên bản được chốt.

Bằng chứng local đã lưu, không chứa trong bản PDF các secret

Source ZIP và patch hai lỗi chạy thật nằm cùng thư mục bàn giao trước. Audit dùng inventory.json, requirements.txt, runtime-probes.json, npm-audit.json và log typecheck/Jest; log Maven/Android ở vùng làm việc. Đây là dấu vết kỹ thuật của lượt rà soát, không phải ảnh triển khai Jenkins/Sonar chưa làm.

Báo cáo được thực hiện bằng rà soát tuần tự và công cụ kiểm tra; không có hội đồng hay nhóm thẩm định độc lập đã chứng nhận. Không có repo mới, push GitHub hoặc triển khai public phát sinh từ việc lập kế hoạch này.

28. Sơ đồ vòng hỗ trợ đề xuất



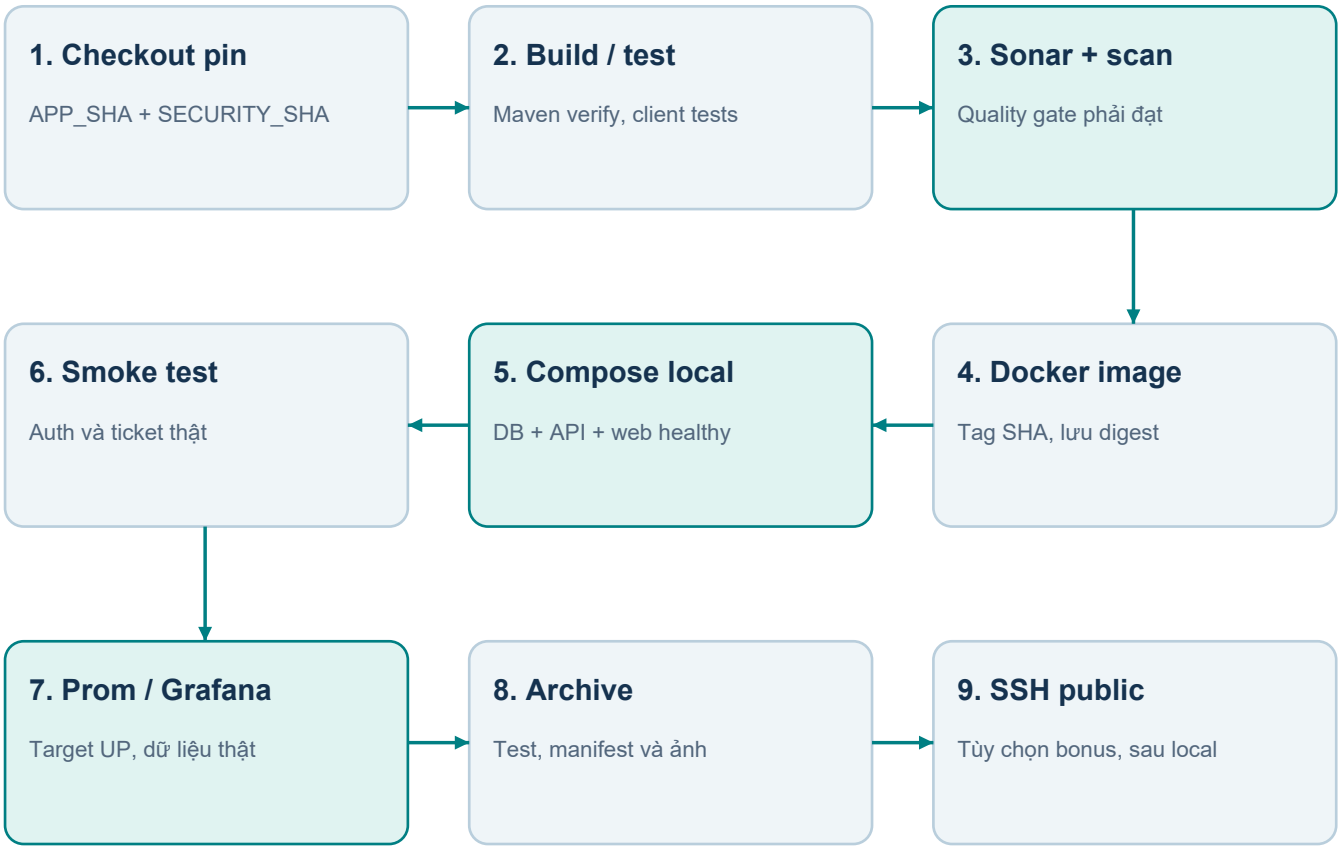
Mũi tên thể hiện luồng chính; nhánh chờ bổ sung quay lại xử lý, nhánh từ chối yêu cầu agent xử lý lại. Bảng chuyển trạng thái ở trang 26 là mô tả đầy đủ quyền/điều kiện. OPEN còn có nhánh requester hủy sang CANCELLED; không phân công lại trạng thái kết thúc.

Thông tin phải đi theo request

Mã yêu cầu, requester, category/team, active assignee, priority, trạng thái, version, lịch sử, bình luận và liên kết file/asset hợp lệ. Mọi actor chỉ nhìn đúng phạm vi của mình. Thông báo hỗ trợ quy trình nhưng không là nguồn quyết định quyền.

Một người có thể mang nhiều vai trò trên các tài nguyên khác nhau. Tên role toàn cục không đủ để bỏ qua requesterId, assigneeId hoặc membership/team ownership của request đang xét.

29. Sơ đồ CI/CD và mô hình chạy



Jenkins nằm trên máy cá nhân theo mẫu. SonarQube gửi kết quả gate về Jenkins qua webhook; không đạt thì không đi tiếp. Monitoring có thể duy trì liên tục bằng stack local riêng sau lần cài đầu, pipeline kiểm tra target/dashboard thay vì cài lại mọi lần.

Luồng truy cập / dữ liệu	Cấu phần đề xuất
Web/mobile → reverse proxy → backend API	Web và API theo URL cấu hình; HTTPS nếu public. DB và công cụ quản trị không mở ra Internet tùy tiện.
Backend → PostgreSQL / file volume	PostgreSQL chứa dữ liệu; volume file giữ attachment; migrations chạy có kiểm soát.
Prometheus → API metrics; Grafana → Prometheus	Scrape trong network local/nội bộ, giới hạn quyền metrics; không chứa userId/ticket text trong label.

30. Chỉ mục nhanh và quyết định cần chốt

Nội dung	Trang
Kết luận, phạm vi, bản đồ source, kết quả kiểm tra	2-6
34 phát hiện F01-F34 có vị trí code	7-23
Mô hình nghiệp vụ, vai trò, state flow và kiến trúc	24-28
MVP và ba học phần	29-34
Ba repo, version và phân công nhóm	35-37
Lịch 14 ngày và ước lượng	38-40
Nghiệm thu, demo, rủi ro và nguồn tham chiếu	41-44
Sơ đồ vòng hỗ trợ và CI/CD đề xuất	45-46

Bốn quyết định cần nhóm xác nhận ngay ngày đầu

• Rubric thật của An toàn thông tin/Kỹ năng lập trình nâng cao; có bắt buộc web/mobile hay kỹ thuật cụ thể nào không?

• Quy định dùng chung đề tài/source/mobile với nhóm khác và cách ghi công trong báo cáo.

• Chọn web tối thiểu cho helpdesk, giữ mobile hiện có; danh sách chức năng hoãn và người chịu trách nhiệm từng gói.

• Mức giờ thực tế mỗi thành viên, ngày nộp chính xác, máy dùng thi và quyền dùng Docker/Jenkins/server public nếu làm bonus.

Việc nên bắt đầu trước: ghim baseline + review hai patch local; dựng Jenkins/Compose song song; viết test quyền/state trước khi mở rộng UI. Sau đó chỉ nhận một lát nghiệp vụ đủ chạy từ người gửi đến người xác nhận.

Ngày lập: 29/10/2026 • Căn cứ nguồn: 8292d13 • Quy mô nhóm: 4 người • Kế hoạch: 14 ngày. Kết luận kỹ thuật chỉ áp dụng trong phạm vi và bằng chứng được nêu.